International Journal of Information Security (2026) 25:171
https://doi.org/10.1007/s10207-026-01331-0

REGULAR CONTRIBUTION

Baseline cybersecurity configuration patterns in Italian public healthcare web portals

Lerina Aversano[2] · Alessandro Caniglia[1] · Stefano Galantucci[2] · Giuseppe Pirlo[1]

Received: 8 March 2026 / Accepted: 31 August 2026
© The Author(s) 2026

Abstract
The progressive digitalisation of public healthcare services has made institutional web portals a critical access point for citizens and professionals alike. This study presents a nation-wide, comparative assessment of Italian regional and provincial healthcare portals, focusing on the presence of baseline security weaknesses observable through passive, non-intrusive scanning. Using OWASP ZAP in baseline mode, we analysed all institutional portals within a single temporal window, collecting severity-labelled vulnerability categories and technology fingerprinting information. To avoid biases related to portal size or content volume, each vulnerability category was counted at most once per portal. The resulting dataset therefore captures configuration and hardening patterns rather than vulnerability frequency or exploitability. Results show a heterogeneous but recurrent set of low- and medium-severity issues across regions and macro-areas, alongside a limited presence of high-severity findings. Several vulnerability classes related to HTTP security headers, cookie attributes, and request-handling mechanisms appear widespread, suggesting uneven adoption of well-established defensive measures. While the analysis does not assess exploitability or operational risk, it provides a reproducible empirical snapshot of baseline security configurations across the Italian public healthcare web ecosystem. The findings support comparative analysis and longitudinal monitoring, offering a reference point for future studies on the evolution of security practices in institutional digital services.

Keywords Web application security assessment · Passive vulnerability scanning · Healthcare portals · National-scale measurement study · e-Health

1 Introduction

The rapid digitalization of healthcare services has turned the institutional websites of Italian Regions and Local Health Authorities (ASL) into critical infrastructures for accessing public services [1]. These portals deliver information and functions of particular sensitivity, including access to medical reports, appointment booking, payments, forms, prevention-campaign updates, and public-utility notices during emergencies [2]. Their central role makes them directly exposed to cyber risk—an exposure compounded by the organizational complexity of the National Health Service (SSN), the territorial distribution of responsibilities, and the heterogeneous technological landscape inherited from years of layered applications [3].

Within the broader European framework, regulatory pressure has raised the bar for confidentiality, integrity, and availability in public digital services. Regulation (EU) 2016/679 (GDPR) [4] sets stringent conditions for the processing of personal data, while legislation on network and information-system resilience (the NIS/NIS2 directive and its implementing acts [5]) stresses risk-proportionate organizational and technical measures, operational continuity, and incident management. At the national level, AgID security measures and technical recommendations for public administrations provide a practical reference for improv-

Lerina Aversano, Alessandro Caniglia, Stefano Galantucci and Giuseppe Pirlo have contributed equally to this work.

✉ Alessandro Caniglia
a.caniglia3@phd.uniba.it

✉ Stefano Galantucci
stefano.galantucci@unifg.it

Lerina Aversano
lerina.aversano@unifg.it

Giuseppe Pirlo
giuseppe.pirlo@uniba.it

[1] University of Bari Aldo Moro, Via Orabona 4, 70125 Bari, Italy

[2] University of Foggia, Via Napoli 25, 71122 Foggia, Italy

Published online: 07 October 2026

ing ICT security through technological, organisational, and procedural controls, including baseline protection measures, monitoring, and progressive improvement of security posture [6]. AgID also provides specific guidance on TLS and cipher-suite configuration and on secure software development practices [7, 8]. These principles are consistent with, rather than equivalent to, DevSecOps-oriented approaches, where security activities are integrated throughout development, deployment, and maintenance workflows [9]. Despite these efforts, empirical analyses and sectoral reports continue to highlight recurring issues: suboptimal TLS configurations, missing or weak security headers, outdated software components, and attack surfaces introduced by third-party dependencies or ancillary services (CDNs, analytics tools, widgets, integration APIs) [10].

Against this backdrop, the present study offers a comparative assessment of the security posture of all provincial ASL portals and regional healthcare websites in Italy, with a specific focus on exposed attack surfaces and baseline protection practices. To this end, each identified domain or host was subjected to passive scanning with the OWASP Zed Attack Proxy (OWASP ZAP), generating uniform HTML and JSON reports. The passive, non-intrusive approach—compliant with ethical and legal constraints—allows for a systematic examination of several aspects: the quality of TLS termination (accepted versions/protocols, certificate chains, HSTS), the presence and configuration of security headers (CSP, X-Frame-Options, X-Content-Type-Options, Referrer-Policy, Permissions-Policy), the use of secure cookies (Secure/HttpOnly/SameSite), indicators of content isolation and XSS-mitigation measures, and signs of technical debt (fingerprintable technologies and libraries, server banners, unnecessary information disclosure).

The main contributions of this work are:

- The development of a consistent evaluation methodology applied to the entire perimeter of sanitary web portals;
- A large-scale measurement of basic hardening practices and the configuration patterns currently in use;
- The identification of territorial and organizational disparities, which can support policymaking and the prioritization of remediation efforts;
- A methodological discussion of the limitations of passive scanning and of the potential benefits of integrating other techniques (SAST/DAST/IAST, continuous monitoring, supply-chain analysis).

The findings aim to inform policymakers, security officers, and the scientific community, encouraging incremental improvement initiatives and periodic benchmarking activities.

2 Background

2.1 Public healthcare web portals and web-facing threat exposure

Healthcare organisations have been repeatedly exposed to cyber incidents over the past decade, and the reasons are by now well understood. Clinical data retain a high value on underground markets, while service disruption can have immediate operational consequences. For this reason, ransomware attacks tend to attract most of the attention. In practice, however, they represent only one part of a broader and more fragmented threat landscape. In this context, public healthcare portals are not critical only because of the services they mediate, but also because they represent externally reachable entry points where organisational, infrastructural, and application-level weaknesses can become visible.

Web-facing healthcare systems are routinely targeted through a variety of vectors. These range from direct exploitation attempts against exposed services to more indirect strategies, such as credential reuse, phishing-driven access, or compromises affecting third-party components. Supply-chain dependencies, external APIs, and shared infrastructure services add further complexity. As a result, the security posture of a healthcare organisation is often influenced by elements that fall outside the boundaries of a single application.

Institutional healthcare portals deserve particular attention in this context. They typically function as entry points to a wide set of digital services and therefore expose multiple layers of infrastructure at once. Alongside the main web interface, these portals frequently rely on additional subdomains, authentication gateways, and supporting services such as DNS and content delivery networks. Over time, legacy components and obsolete endpoints may remain accessible, not because they are actively maintained, but simply because they were never fully decommissioned.

Several documented incidents illustrate how weaknesses at this level can translate into real consequences. In one case, Molina Healthcare temporarily shut down its patient portal after a flaw enabled unauthorised access to patient claims [11]. In another, a breach at UC Davis Health originated from a phishing campaign that targeted an employee and ultimately led to the exposure of sensitive patient information [12]. These episodes are not exceptional; rather, they reflect structural issues that tend to recur whenever public-facing healthcare services evolve faster than the security practices that support them.

2.2 Privacy concerns and user trust in e-health services

Technical security measures alone do not determine the success of e-health services. User perception, trust, and perceived risk play an equally important role in shaping adoption and long-term use. Several empirical studies show that concerns related to identity theft, unauthorised access, or secondary use of personal health information discourage patients from engaging with online healthcare portals [13, 14]. These concerns are often expressed even in contexts where no concrete incident has occurred.

Limited health and digital literacy further complicate this picture, as users' ability to seek, understand, and evaluate online health information and related privacy and security mechanisms can influence their confidence in e-health services [13–15]. When users do not fully understand how authentication mechanisms, session controls, or data-protection measures work, security features may appear opaque or unreliable. In such cases, the presence of technical safeguards does not necessarily translate into increased confidence, and may even raise additional doubts.

At the same time, user attitudes are not fixed. Prior work suggests that initial anxiety may diminish after repeated interaction with protected access mechanisms, such as secure login workflows or identity-verification procedures [16]. Familiarity with these systems can foster a degree of reassurance, at least in the short term. Nevertheless, broader concerns about large-scale data breaches or misuse of health information persist and are frequently reinforced by media coverage of security incidents.

This tension between convenience, perceived benefit, and perceived risk remains a defining factor in the adoption of e-health portals. From a security perspective, it highlights the importance of not only implementing technical protections, but also ensuring that such measures are applied consistently and in ways that are visible and understandable to end users.

2.3 Regulatory and organisational context

Security practices in the healthcare sector are shaped by a layered and, in some respects, fragmented regulatory environment. At European and national level, frameworks such as the General Data Protection Regulation (GDPR) [17] and the NIS and NIS2 directives [18] define general obligations related to data protection and cybersecurity. These instruments provide an overarching reference, but they do not prescribe detailed technical implementations.

In everyday operational settings, high-level regulatory requirements are interpreted through a combination of technical standards, best practices, and organisational habits. Protocol-level security is still largely governed by Requests for Comments (RFCs) and Best Current Practices. DNSSEC remains the standard mechanism for protecting domain-related data [19], while recommendations on TLS versions, cipher suites, and protocol parameters continue to evolve over time [20]. OCSP stapling [21] is intended to improve certificate-status checking, although its deployment across real-world infrastructures is often uneven.

Alongside these technical references, practitioners frequently rely on hardening guidelines. The CIS Benchmarks [22] and OWASP materials, including the Web Top Ten [23] and the API Top Ten [24], are widely cited and inform many operational decisions. Their adoption, however, is rarely uniform. Legacy constraints, tooling limitations, and local priorities influence how closely such recommendations are followed in practice. Formal management frameworks such as ISO/IEC 27001 and 27002 [25, 26] provide an organisational structure for security programmes, while ENISA's threat reports [27] are often used as contextual references rather than strict guidance.

Within the Italian public administration, national guidance issued by AgID [6, 28] seeks to translate international principles into more concrete operational expectations. These documents address topics such as HTTPS adoption, TLS hardening, certificate management, security headers, vulnerability management, logging, and incident response. Despite this, implementation remains heterogeneous. Differences in organisational maturity, the presence of legacy infrastructures, and limited availability of specialised personnel contribute to a landscape in which regulatory objectives are broadly acknowledged, but their technical realisation varies significantly across administrations.

2.4 Baseline hardening practices for public web portals

What is generally considered "baseline" security for public web portals is not particularly controversial. Most of the underlying controls have been discussed for years and are well documented in standards and operational guidelines. The gap, as often noted in practice, lies less in awareness than in consistent implementation.

Transport security is usually treated as a starting point. Older protocols such as SSLv3 or early TLS versions are widely discouraged [29], and modern TLS configurations are recommended [20]. In real deployments, however, configurations are often uneven. HSTS may be enabled without covering subdomains, certificate management may rely on manual processes, and supporting elements such as DNS redundancy are sometimes addressed only after problems arise. OCSP stapling [21], while frequently mentioned in guidance, is still missing or misconfigured in a non-negligible number of cases.

At application level, HTTP security headers are a recurring indicator of how carefully a web surface is managed.

Content Security Policy [30, 31] is widely recognised as an effective mitigation against client-side attacks, yet its actual configurations vary significantly. In some cases, policies are strict and carefully maintained; in others, they are permissive or only partially deployed. Similar considerations apply to headers such as X-Content-Type-Options, frame-ancestors or X-Frame-Options, Referrer-Policy, and Permissions-Policy, which are commonly recommended but not consistently present [22].

Session and cookie handling represents another area where guidance and practice do not always align. The use of Secure, HttpOnly, and SameSite attributes is broadly recommended, together with application-level defences against cross-site request forgery [32]. In practice, these controls may be applied selectively, for example only to specific cookies or endpoints, limiting their overall effectiveness.

A number of hardening measures focus on reducing unnecessary information exposure. Recommendations such as minimising server banners, disabling directory listings, or standardising error responses are relatively simple to implement [22], yet they are frequently overlooked. Cross-origin resource sharing configurations also require careful attention, as permissive rules can undermine otherwise reasonable security setups [33].

When external resources are involved, additional mechanisms become relevant. Subresource Integrity [34] is one example, particularly in the context of supply-chain risks that have received increasing attention in recent threat analyses [35]. At a broader organisational level, DNS and email-related controls—such as DNSSEC [19], DMARC [36], SPF [37], and DKIM [38]—are often treated as indicators of general security discipline, even though they are not directly tied to application logic.

Finally, many public portals rely on defence-in-depth mechanisms, including web application firewalls and CDN-based protections [39, 40]. These technologies can reduce exposure to common attack patterns, but they do not compensate for weak baseline configurations. More recently, practices such as publishing a security.txt file [41] have been promoted to support responsible vulnerability disclosure. Taken together, these elements outline a baseline that is broadly recognised, even if real-world adoption remains partial and inconsistent. Because several of these controls and weaknesses are referred to by acronyms in the empirical results, Table 1 summarises the main categories considered in this study. The table is intended as a terminology guide rather than as a taxonomy of exploitable vulnerabilities, since the passive scanning approach adopted in this work only observes externally visible configuration patterns.

3 Related work

3.1 Large-scale web security measurement and passive assessment

Security assessment methodologies are commonly grouped into code-centric and runtime-centric approaches. Static Application Security Testing (SAST) analyses source code, bytecode, or binaries without executing the application, and is therefore useful for identifying implementation-level weaknesses early in the development lifecycle. Dynamic Application Security Testing (DAST), by contrast, observes the behaviour of a running application from the outside, typically by interacting with exposed endpoints and analysing the resulting responses. Interactive Application Security Testing (IAST) combines runtime observation with instrumentation, while Runtime Application Self-Protection (RASP) focuses on detecting or blocking malicious behaviour during application execution [9].

These approaches provide complementary perspectives, but they also differ significantly in terms of access requirements, intrusiveness, and operational risk. SAST and IAST generally require access to source code, binaries, or instrumented environments, which is rarely available in large-scale assessments of public-sector web infrastructures. Active DAST can provide deeper evidence of exploitability, but it may generate traffic patterns or payloads that are not appropriate when analysing production systems operated by public administrations. These constraints are particularly relevant in healthcare, where service continuity, proportionality, and the sensitivity of the service context are central concerns.

In contrast, passive analysis techniques focus on externally observable characteristics without injecting payloads or attempting exploitation. Tools such as OWASP ZAP operating in passive-scan mode inspect HTTP headers, TLS configurations, cookie attributes, and other metadata exposed to unauthenticated users [23, 31]. Passive approaches are particularly suitable for large-scale assessments of public-sector infrastructures, as they reduce operational risk and legal concerns while enabling consistent cross-domain comparison [22, 35]. However, their limitations are well documented: they cannot detect logic-driven vulnerabilities, authenticated workflow issues, or vulnerabilities that require stateful interaction, and their coverage depends on the observable surface exposed during the scan.

This non-intrusive measurement perspective is consistent with a broader strand of empirical web-security research that relies on externally observable indicators to compare heterogeneous websites. Large-scale studies on HTTP secu-

Table 1 Main vulnerability and configuration categories considered in the study

Acronym /label	Full category	Meaning in this study	References
CSP	Missing or incomplete Content Security Policy	Indicates the absence or weakness of a Content Security Policy header, which can reduce browser-side protection against script injection and content-loading abuse	[30, 31]
HSTS	Missing Strict-Transport-Security header	Indicates that the portal does not explicitly instruct browsers to enforce HTTPS connections for subsequent requests, potentially weakening transport-layer protection	[29, 42]
XCTO	Missing X-Content-Type-Options header	Indicates the absence of the `X-Content-Type-Options` header, which helps prevent MIME-type sniffing and related content interpretation issues	[43]
XFO	Missing anti-clickjacking header	Indicates the absence of frame-protection mechanisms, such as `X-Frame-Options` or equivalent CSP directives, which can expose pages to clickjacking scenarios	[44]
CS	Cookie without SameSite attribute	Indicates that at least one cookie lacks the `SameSite` attribute, reducing protection against cross-site request contexts	[32]
CSEC	Cookie without Secure flag	Indicates that at least one cookie is not explicitly restricted to HTTPS transmission through the `Secure` attribute	[32]
CSRF	Missing Anti-CSRF token	Indicates that ZAP did not detect an explicit anti-CSRF token in relevant forms or state-changing request patterns. This does not by itself prove exploitability, but suggests that request-forgery protections may be incomplete or not externally observable	[45]
XJS	Cross-domain JavaScript inclusion	Indicates that JavaScript resources are loaded from external domains, increasing reliance on third-party resources and making supply-chain or trust-boundary considerations relevant	[34, 46]
TS	Timestamp disclosure	Indicates that responses expose timestamp information that may reveal implementation details or support fingerprinting and reconnaissance	[47]
XPB	X-Powered-By information disclosure	Indicates that the `X-Powered-By` header or similar metadata reveals server-side technology information, which can facilitate fingerprinting	[43, 47]

The reference column points to the OWASP guidance and normative specifications where readers can find further information on each category

rity headers and web hardening practices have examined the deployment of Content Security Policy, Strict-Transport-Security, X-Frame-Options, X-Content-Type-Options, and related browser-side protections across broad web populations, showing that even mature controls are adopted unevenly [48, 49].

Although these studies provide useful evidence on baseline web-hardening practices, they generally analyse broad web populations rather than focusing specifically on public healthcare portals as a distinct institutional category. At the same time, healthcare cybersecurity literature and institutional reporting often focus on incidents, sectoral threats, governance, interoperability, regulatory obligations, or organisational resilience, rather than on reproducible passive measurement of portal-level web configurations [50–53]. This creates a gap between general web-security measurement and healthcare-sector cybersecurity analysis, which the present study addresses through a national-scale passive assessment of Italian public healthcare portals.

The present work follows this measurement tradition, but applies it to a sector-specific institutional ecosystem that remains less explored through systematic passive scanning: Italian public healthcare portals. Unlike general-purpose web measurements, the objective is not to characterise the Web at large, but to provide a reproducible national-scale snapshot of baseline configuration patterns in a regulated healthcare environment.

3.2 Security indicators in public-sector and healthcare web portals

Studies that analyse large numbers of public-sector websites usually converge on a limited set of indicators. This is rarely a theoretical choice. Instead, it reflects what can be observed in a repeatable way when many heterogeneous systems are involved, often with little or no access beyond what is publicly exposed.

TLS configuration is one of the aspects most frequently examined, together with the use of HSTS [20, 29]. These

elements are relatively easy to verify remotely and tend to provide a first indication of operational discipline. Security headers are another common focus, largely because they are directly visible to unauthenticated clients and can be inspected without interacting with application logic [31]. Headers such as Content Security Policy, X-Content-Type-Options, X-Frame-Options, Referrer-Policy, and Permissions-Policy are widely used as indicators of baseline hardening because they reflect explicit configuration choices made at the web layer.

Session and cookie attributes are also frequently considered in observational studies. The presence of Secure, HttpOnly, and SameSite attributes does not guarantee complete session security, but their absence may indicate incomplete adoption of basic browser-side protections [32]. Similarly, the detection of missing Anti-CSRF tokens, cross-domain JavaScript inclusion, or information-disclosure headers is typically interpreted as an externally visible signal of configuration or design practices rather than as definitive evidence of exploitability.

In public-sector and healthcare contexts, these indicators require particular caution. Public portals may expose heterogeneous services, integration points, authentication gateways, and citizen-facing workflows, but passive measurements can observe only the unauthenticated and externally reachable portion of this ecosystem. Prior studies and reviews on e-health portals and healthcare cybersecurity emphasise privacy, trust, resilience, interoperability, and the sensitivity of patient-facing digital services [52, 53]. Sectoral analyses also show that healthcare organisations are exposed to ransomware, data breaches, and availability-related disruptions, reinforcing the importance of robust public-facing digital infrastructures [50, 51].

At the same time, several strands of healthcare cybersecurity literature and institutional reporting focus primarily on incidents, sectoral threats, governance, regulatory obligations, interoperability, or organisational resilience, rather than on reproducible passive measurement of portal-level web configurations [50–53]. Conversely, large-scale web-security studies often analyse broad web populations and baseline hardening controls, such as HTTP security headers, without isolating public healthcare portals as a distinct institutional category [48, 49]. This creates a gap between general web-security measurement and healthcare-sector cybersecurity analysis, which the present study addresses through a national-scale passive assessment of Italian public healthcare portals.

For similar reasons, many studies include some form of technology fingerprinting, typically limited to what can be inferred from headers, page content, or resource loading patterns. Other indicators are included less consistently [54–56]. Some analyses attempt to identify outdated or vulnerable components based on observable version information, even though this approach is necessarily approximate. DNS- and email-related controls, such as DNSSEC or DMARC, are also considered in a number of works, despite not being strictly tied to the web layer [19, 36]. The presence of a vulnerability disclosure mechanism, often implemented through a security.txt file, has recently gained attention as a signal of organisational readiness to handle external reports [41].

Responsible disclosure mechanisms are especially relevant in large-scale observational studies, where researchers must balance transparency, reproducibility, and the risk of misuse. In this perspective, the presence of disclosure channels, including security.txt, should not be interpreted as a vulnerability or as a direct security control, but as an organisational signal related to external reporting and remediation processes [41]. This distinction is aligned with the ethical positioning of the present study, which reports scanner-observed configuration signals without providing exploit-ready technical details.

Finally, several studies use externally visible cues as a rough proxy for technical debt. Examples include long-standing framework versions, outdated client-side libraries, or limited evidence of recent maintenance. These indicators are clearly imperfect, but they are frequently adopted in large-scale observational settings as a way to capture maintenance-related issues that would otherwise remain hidden [57].

3.3 Metrics, benchmarking strategies, and research gap

To enable meaningful comparison across heterogeneous systems, prior work emphasises the use of normalised metrics rather than raw counts [58]. This issue is particularly important when the analysed portals differ substantially in size, number of pages, number of exposed services, and degree of internal segmentation. Raw vulnerability counts may over-represent larger portals simply because they expose more pages or resources, even when the underlying configuration weakness is the same.

Common approaches include measuring control coverage, configuration quality, and TLS maturity [59–62]. Some studies aggregate scanner outputs into synthetic exposure scores, weighting findings according to severity scales [63]. Others focus on binary or presence-based indicators, recording whether a given weakness is present at least once within a host or portal. This strategy reduces duplication effects and is particularly useful when the aim is to compare baseline posture rather than vulnerability density.

Technology fingerprinting is often used as a proxy for technical debt and long-term maintenance practices [57]. However, fingerprinting-based indicators require cautious interpretation, because externally visible technologies may represent only part of the deployed architecture and version

information may be hidden, masked, or distorted by intermediaries such as reverse proxies, CDNs, and web application firewalls.

Across these studies, methodological transparency remains a central requirement. Inclusion criteria, scan timing, scanner version, crawler scope, handling of redirects and duplicate domains, severity mapping, treatment of false positives, and aggregation strategy can substantially influence results. For this reason, large-scale security measurements are most useful when they clearly distinguish between observed configuration signals, inferred exposure patterns, and confirmed vulnerabilities.

The gap addressed by the present study lies at the intersection of these strands of literature. Existing web-security measurements provide useful evidence on the uneven deployment of HTTP security headers, TLS-related controls, cookie attributes, and other baseline hardening mechanisms, but they are generally not focused on public healthcare portals. Healthcare cybersecurity studies and institutional reports highlight the sensitivity, regulatory exposure, and threat landscape of the sector, but they rarely provide reproducible, portal-level passive measurements of externally observable configurations.

This study contributes to filling that gap by combining a conservative passive-scanning methodology, presence-based counting, technology fingerprinting, severity-weighted exploratory scoring, and regional and macro-area aggregation. Its contribution is not to validate exploitability or to rank individual administrations, but to provide a reproducible national-scale empirical snapshot of baseline security configuration patterns across Italian public healthcare portals.

4 Methodology

4.1 Scope and portal selection criteria

The portal list was constructed before the scanning phase using official institutional sources. The primary source was the official open-data dataset of Italian Local Health Authorities published by the Italian Ministry of Health, which provides the national list of ASLs and related institutional information for the years 2010–2025 [64, 65]. This source was complemented, when necessary, by the official websites of Italian Regions and Autonomous Provinces and by records from the Italian Public Administration Index (IndicePA/IPA), used to verify institutional naming, organisational changes, and official web domains [66, 67].

The objective was to identify the public institutional web portals of regional healthcare services and local healthcare authorities operating within the Italian National Health Service. The list was therefore not generated through search-engine discovery or through automated crawling, but through a manual reconciliation of official institutional sources.

The unit of analysis was the public web portal associated with a healthcare authority, rather than the administrative organisation in the abstract. This distinction is important because Italian healthcare authorities may expose their services through different naming conventions and organisational models across regions, including ASL, ASP, ATS, AST, AUSL, ULSS, and other regional denominations. When an authority exposed a distinct official public portal, the corresponding canonical URL was retained as a candidate target. When multiple URLs referred to the same institutional portal, redirected to the same effective endpoint, or represented aliases of the same service, they were consolidated into a single entry before analysis.

The inclusion criteria were the following: the portal had to be an official public healthcare authority website; it had to belong to a regional, provincial, or local public healthcare institution; it had to expose a publicly reachable unauthenticated web endpoint during the scanning window; and it had to provide institutional or citizen-facing healthcare information or services. Private healthcare providers, non-institutional websites, purely informational third-party pages, and services not attributable to a public healthcare authority were excluded.

Unavailable portals were not analysed. In particular, candidate URLs that returned persistent connection errors, did not resolve, were inaccessible during the scanning window, or did not expose a stable public web endpoint were excluded from the final dataset. Similarly, subdomains or additional hosts encountered during crawling were not added as independent portals unless they had already been identified during the portal selection phase as distinct official institutional portals.

The final dataset consisted of 130 public healthcare portals. For each portal, the dataset retained the region, macro-area, canonical URL, effective scan target when redirects occurred, detected technologies, severity-labelled alert counts, presence-based vulnerability categories, and the severity-weighted risk score. The complete list of analysed portals is reported in the Appendix to support transparency and reproducibility.

The overall workflow of the study is summarised in Fig. 1. The process starts from the definition of the institutional perimeter and the construction of the portal list from official sources, followed by the application of inclusion and exclusion criteria and the consolidation of duplicate or redirected targets. The selected portals were then analysed using OWASP ZAP in baseline mode, including the crawler/spider phase and passive analysis of publicly reachable, unauthenticated pages. The resulting JSON reports were extracted and normalised through presence-based counting, classified by severity, enriched with technology fingerprinting infor-

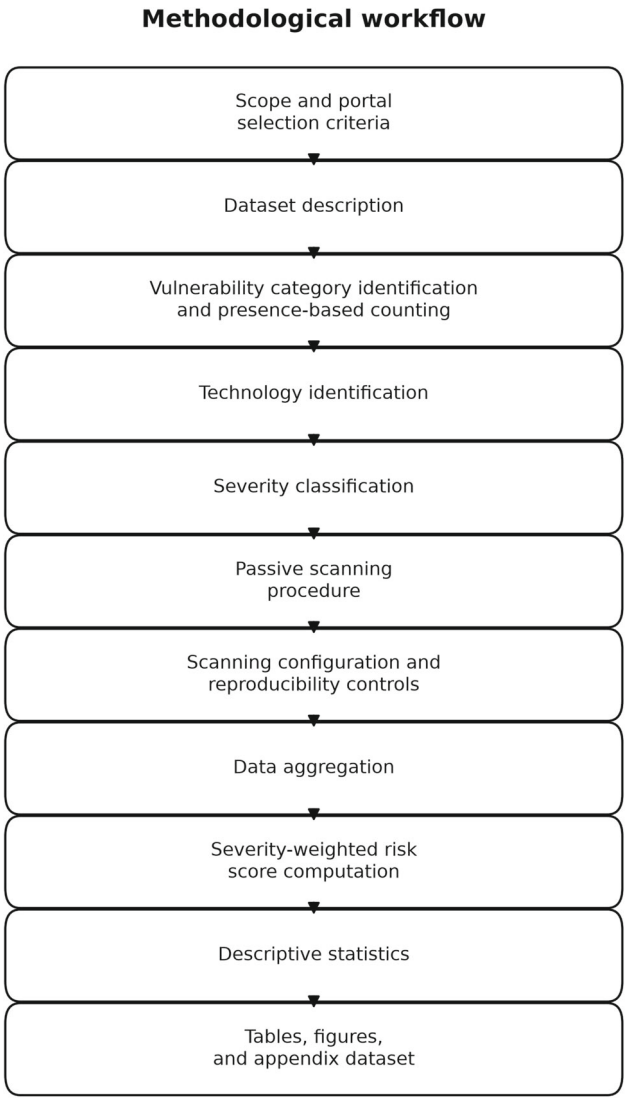


Fig. 1 Methodological workflow adopted in the study, from official-source portal selection to OWASP ZAP baseline scanning, JSON extraction, presence-based normalisation, aggregation, and comparative post-analysis. Each processing step is named after the subsection of Sect. 4 the same order; the final block indicates the reported outputs.

mation, and aggregated at portal, regional, and macro-area levels. Finally, severity-weighted risk scores and descriptive statistics were computed to support comparative analysis. To help the reader navigate the methodology, each step in the figure is named after the subsection in which it is described and appears in the same order.

4.2 Dataset construction and classification

4.2.1 Dataset description

The dataset used in this study was generated from 130 institutional public healthcare web portals. These portals correspond to the set of regional and provincial healthcare websites that were publicly accessible and officially active at the time of the analysis, covering all Italian regions and autonomous provinces. Each portal is considered as a single unit of analysis, irrespective of the number of pages, services, or internal sections it exposes.

For each portal, the dataset records a small number of attributes derived from passive observation. In particular, it includes information on whether specific vulnerability categories are present. In addition, the dataset contains data on externally visible technologies, such as server platforms, content management systems, and commonly used client-side libraries, as inferred from headers and resource-loading patterns. Finally, a synthetic score is associated with each portal, obtained by combining the detected vulnerability categories using a severity-weighted aggregation scheme.

The distribution of portals across regions is uneven. This reflects differences in how regional healthcare systems organise their digital services, with some regions exposing multiple distinct portals and others relying on more centralised solutions. Because of this variability, the dataset is analysed from more than one perspective. Alongside aggregate counts, the analysis also makes use of normalised views, such as average values computed at the portal level, in order to reduce the influence of regional size effects.

The dataset should be interpreted as a snapshot taken within a single and well-defined time window. It captures the configuration that was observable during the scanning phase and does not attempt to track changes over time or subsequent remediation actions. A complete, per-portal representation of the dataset, including detailed severity counts, computed scores, and detected technologies, is reported in the Appendix to allow inspection of individual cases and to support reproducibility.

4.2.2 Vulnerability category identification and presence-based counting

The data obtained on vulnerabilities through OWASP ZAP was refined using a presence-based counting strategy. For each portal, each vulnerability category identified by the scanner was recorded only once, regardless of the number of pages or endpoints that had the same problem.

This presence-based counting strategy was adopted to avoid systematically penalising portals with larger content volumes or more complex navigation structures. Rather than measuring frequency, the analysis captures whether a given class of weakness is present at all within the portal perimeter. This approach aligns with prior large-scale studies that focus on configuration breadth and baseline security posture rather than on vulnerability density [58].

As a consequence, two portals exposing the same vulnerability category are treated equivalently, even if the number of

affected resources differs substantially. The resulting dataset, therefore, reflects structural configuration and hardening patterns at the portal level.

4.2.3 Technology identification

During the data collection phase, publicly observable information was also used to identify the main web technologies employed by each portal. Technology identification was performed by analysing HTTP response headers, resource loading patterns, and other metadata exposed to unauthenticated users during the passive scanning process.

The following were therefore recorded for each portal: server platforms, content management systems, front-end frameworks, and widely used client-side libraries. Technology identification was not intended to provide a complete architectural view of each portal, but rather to capture externally visible components that may influence configuration practices and maintenance strategies.

The resulting technology information was used to contextualise the observed vulnerability patterns and to support qualitative interpretation of the results, without being directly incorporated into the risk score computation.

4.2.4 Severity classification

Each detected vulnerability category was associated with a severity level (High, Medium, Low, or Informational) according to the classification scheme adopted by OWASP ZAP. Each scanner-reported finding was recorded according to the risk indication provided by OWASP ZAP. In particular, some vulnerability categories may present different levels of risk depending on the specific underlying evidence; for example, the risk associated with a vulnerable JavaScript library depends on the CVEs known for that library. Severity labels provide a coarse-grained indication of potential impact under generic conditions, but they do not account for exploitability, exposure context, or compensating controls.

In this study, severity levels were used solely for aggregation and comparative purposes. Given the passive nature of the scans, severity should not be interpreted as a direct proxy for operational risk.

4.3 Experimental procedure and post-analysis

4.3.1 Passive scanning procedure

Data acquisition was performed using OWASP ZAP in baseline scan mode. This configuration relies exclusively on passive analysis techniques, inspecting HTTP responses, TLS parameters, and other externally observable characteristics without injecting payloads or attempting exploitation [23, 31]. Each of the identified portals was fed into OWASP ZAP, and the data obtained from the tool's JSON output was aggregated.

The choice of passive scanning was motivated by ethical, legal, and operational considerations. Unlike active Dynamic Application Security Testing (DAST), the baseline mode does not interfere with application logic or service availability and is therefore suitable for large-scale assessments of public-sector infrastructures [22, 35]. At the same time, it allows consistent comparison across heterogeneous systems, which is a common requirement in national-scale measurement studies.

It is important to stress that passive scanning does not assess exploitability, business impact, or the effectiveness of internal security controls. The detected findings reflect externally observable configuration patterns and hardening practices rather than confirmed vulnerabilities.

4.3.2 Scanning configuration and reproducibility controls

To improve reproducibility, all scans were executed using OWASP ZAP version 2.16.1 in baseline scan mode within a single-day scanning window on 5 November 2025. Each portal was scanned starting from the canonical public URL identified during the portal selection phase. The baseline scan included the crawler/spider phase provided by OWASP ZAP, followed by passive analysis of the HTTP responses collected during navigation. Therefore, the assessment was not limited to the landing page alone, but included publicly reachable pages discovered by the crawler within the scan context.

HTTP redirects were followed during scanning. When an initial URL redirected to another address, the resolved destination was treated as part of the effective scan target. Duplicate entries that referred to the same institutional service or resolved to the same effective portal were consolidated before aggregation, so that each portal was retained as a single unit of analysis. Portals that were not reachable during the scanning window, returned persistent connection errors, or did not expose a stable public web endpoint were not analysed and were not included in the final dataset.

The assessment was restricted to publicly accessible and unauthenticated surfaces. No credentials were used, no restricted areas were accessed, and no active exploitation or payload-based attack was performed. Subdomains and additional hosts discovered during crawling were not used to expand the sampling frame automatically. They were considered only as resources observed within the scan context of the originating portal, unless they had already been identified as distinct institutional portals during the portal selection phase.

The JSON output generated by OWASP ZAP was used as the primary source for alert extraction. Alerts were normalised by portal and by vulnerability category. In accordance with the presence-based counting strategy adopted in

this study, repeated occurrences of the same alert category within the same portal were collapsed into a single presence indicator, regardless of the number of affected URLs. Informational alerts were retained for inspection but were not included in the severity-weighted risk score, which was computed only from Low-, Medium-, and High-severity categories.

No manual exploitability validation was performed. High-severity alerts were therefore retained according to the severity labels assigned by OWASP ZAP and interpreted as scanner-reported findings. This choice is consistent with the passive and non-intrusive design of the study. Consequently, the results are reported as vulnerability categories, configuration weaknesses, or externally observable security signals, rather than as confirmed exploitable vulnerabilities.

4.3.3 Data aggregation

Following data collection, the identified vulnerability categories were aggregated to support comparative analysis across different territorial and organisational levels. Aggregation was performed at the portal, regional, and macro-area levels to enable the exploration of both local and broader exposure patterns. The organisation by region refers to the regions of the Italian state's political geography. Each portal was therefore assigned to the geographical region to which it belongs. Since Italy extends predominantly along a north–south axis, its regions are conventionally grouped into three geographic macro-areas according to their position along that axis. Each region was accordingly assigned to the North, the Centre, or the South on the basis of its geographic position. The organisation into macro-areas was defined as follows:

- North: Valle d'Aosta, Piemonte, Liguria, Lombardia, Emilia-Romagna, Trentino-Alto Adige, Veneto, Friuli-Venezia Giulia;
- Centre: Toscana, Umbria, Marche, Lazio, Abruzzo, Sardegna;
- South: Molise, Campania, Puglia, Basilicata, Calabria, Sicilia.

Portal-level aggregation captures the number of distinct vulnerability categories observed for each individual system. Regional and macro-area aggregations were then derived by combining portal-level data, allowing the identification of heterogeneity across geographical areas.

4.3.4 Severity-weighted risk score computation

To support exploratory comparison across portals, a severity-weighted risk score was computed by combining the number of distinct vulnerability categories detected at each severity level. The score is defined as a linear combination:

$$\text{RiskScore} = w_H \cdot N_H + w_M \cdot N_M + w_L \cdot N_L \quad (1)$$

where N_H, N_M, and N_L represent the number of distinct High-, Medium-, and Low-severity vulnerability categories detected for a given portal, and w_H, w_M, and w_L are fixed weights reflecting the ordinal severity scale. In this study, weights were chosen such that $w_H > w_M > w_L$, following common practice in vulnerability aggregation [63]. In the reported results, weights were set to $w_H = 3$, $w_M = 2$, and $w_L = 1$.

The resulting score is not intended to represent an absolute or operational measure of risk. Instead, it serves as a synthetic indicator to facilitate relative comparison and to highlight variability in exposure breadth across portals and regions. Given the presence-based counting strategy and the reliance on passive observations, the score should be interpreted with caution and used only as an exploratory metric. Despite its simplicity, this formulation allows consistent cross-portal comparison at the national scale, which is rarely feasible with more intrusive assessment techniques.

4.3.5 Descriptive statistics

To further characterise the distribution of portal-level exposure within each territorial group, descriptive statistics were computed at regional and macro-area levels. In particular, for each group we report the number of analysed portals, the median, and the interquartile interval of the number of Low-, Medium-, and High-severity findings, as well as of the severity-weighted risk score. Quartiles were computed on portal-level values using linear interpolation, and the interquartile interval is reported as Q1–Q3. This choice provides a robust summary of central tendency and dispersion, reducing the influence of outliers and uneven regional portal counts.

4.3.6 Methodological limitations

Many limitations must be acknowledged. Passive scanning cannot detect vulnerabilities that depend on application logic, authentication context, or user interaction, nor can it assess internal monitoring or incident response capabilities [9]. Automated tools may also produce false positives or miss context-dependent mitigations.

In addition, high-severity findings were not manually validated through exploitation attempts or authenticated testing. They therefore represent OWASP ZAP severity-labelled alerts observed during passive scanning, not confirmed exploitable vulnerabilities. This limitation was intentionally

accepted to preserve the non-intrusive nature of the assessment.

Despite these constraints, the uniform application of a conservative, non-intrusive methodology across a complete national dataset enables consistent comparison and supports the identification of recurring patterns in baseline security configurations.

4.4 Ethical considerations and disclosure

The study was designed as a passive, non-intrusive assessment of publicly reachable web surfaces. No credentials were used, no authenticated areas were accessed, no personal or health-related data were collected, and no attempt was made to exploit, modify, disrupt, or bypass any portal functionality. The analysis was limited to externally observable configuration signals and scanner-reported alerts generated from public HTTP responses.

Because the findings were produced through passive scanning and were not manually validated through exploitation attempts, they are interpreted as vulnerability categories, configuration weaknesses, or externally observable security signals rather than as confirmed exploitable vulnerabilities. For this reason, the study does not disclose proof-of-concept exploits, payloads, sensitive endpoint details, or operational instructions that could facilitate misuse. Results are primarily reported in aggregated form by region, macro-area, severity, and category. In addition, no endpoint-level evidence, request traces, or exploitability details are reported in the manuscript or appendices.

A summary of the study findings was forwarded to the relevant institutional stakeholders and competent administrations. The communication was intended to support prioritisation and remediation activities, while avoiding the disclosure of exploit-ready technical details. Given the passive and non-intrusive nature of the assessment, and the absence of manual exploitability validation, the shared material should be interpreted as a set of scanner-reported configuration signals rather than as a disclosure of confirmed exploitable vulnerabilities. Where individual portal-level information is made available for transparency and reproducibility, it should be interpreted as a prioritisation aid for defensive review and remediation, not as evidence of confirmed vulnerabilities.

5 Results

5.1 Overview of analysed portals

The empirical results presented in this section are based on 130 institutional healthcare portals covering regional and provincial public health websites in Italy. All portals were analysed within a single temporal window using the same passive scanning configuration, allowing comparison across regions and macro-areas.

The results are organised around four complementary perspectives: aggregate distributions by macro-area, regional variability, vulnerability-category prevalence, and severity-weighted risk indicators. Descriptive statistics further summarise portal-level exposure through medians and interquartile intervals at regional and macro-area levels.

For transparency and reproducibility, the full list of analysed portals, together with their detected technologies, severity counts, and severity-weighted risk scores, is reported in the Appendix.

5.2 Macro-area distribution of vulnerability categories

Figure 2 shows the aggregate distribution of distinct vulnerability categories across the three Italian macro-areas, broken down by severity level. Even at this level of aggregation, the picture that emerges is clearly non-uniform.

The Northern macro-area concentrates the largest number of vulnerability categories, followed by the Centre and, at some distance, the South. This pattern is not unexpected and likely reflects the broader technological diversity and organisational complexity that characterise many northern healthcare infrastructures. At the same time, the overall composition of vulnerabilities is remarkably consistent across macro-areas. In all three cases, low- and medium-severity findings account for the vast majority of observed issues, while high-severity vulnerabilities represent only a small fraction of the total.

The presence of high-severity findings across all macro-areas, albeit in limited numbers, is nonetheless noteworthy. It indicates that potentially high-impact weaknesses are not confined to specific parts of the country, but appear sporadically throughout the national landscape.

Because vulnerabilities are counted only once per portal, the observed differences should not be interpreted as a measure of how often a weakness manifests itself, but rather as an indication of how broadly different classes of weaknesses are present within each macro-area. In this sense, the figure captures differences in exposure breadth and configuration practices, rather than portal size or content volume.

5.3 Regional heterogeneity in vulnerability presence

A finer-grained perspective is provided by the regional aggregation shown in Fig. 3. At this level, variability becomes even more pronounced. Some regions exhibit a relatively limited number of distinct vulnerability categories, while others show a much wider spread across low-, medium-, and, in a few cases, high-severity findings.

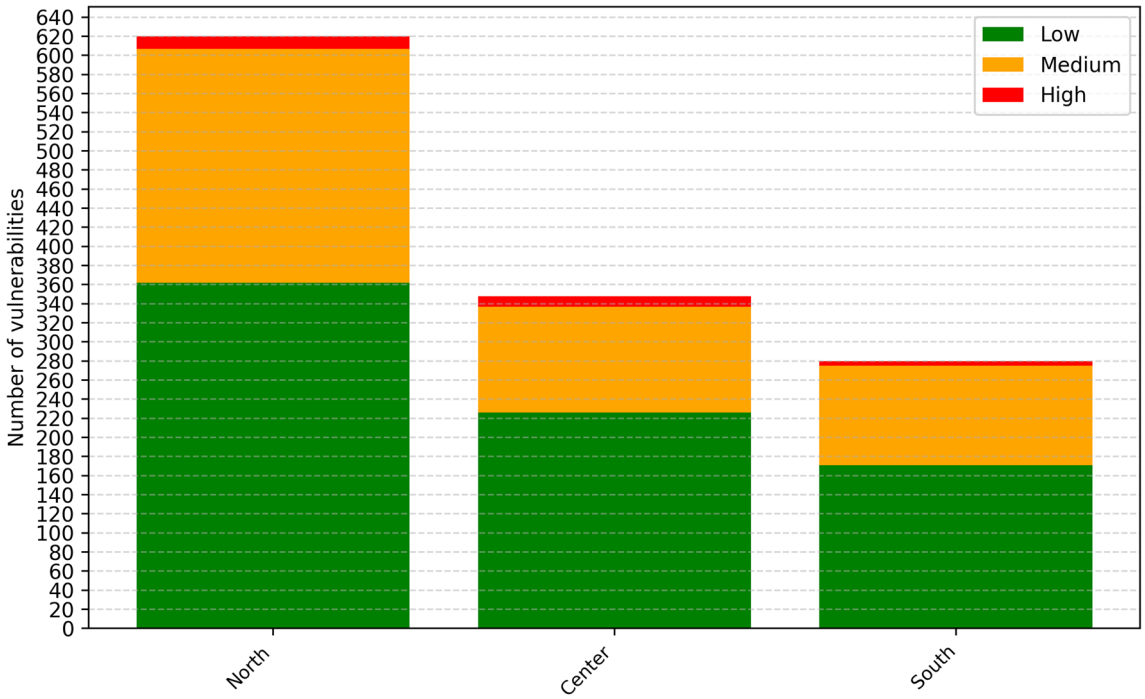


Fig. 2 Aggregate distribution of distinct vulnerability categories across Italian macro-areas, grouped by severity

Regions such as Veneto, Emilia-Romagna, Sardegna, Sicilia, and Lombardia stand out for the breadth of vulnerability categories detected across their portals. Conversely, regions including Marche, Puglia, and Valle d'Aosta present a more restricted vulnerability profile. These differences do not align neatly with geographic location or simple demographic indicators, suggesting that regional size alone is insufficient to explain the observed patterns.

Rather than pointing to "better" or "worse" regions, this distribution highlights the heterogeneous nature of regional healthcare web ecosystems. Differences in governance models, levels of centralisation, procurement strategies, and historical layering of digital services are all plausible contributing factors. For this reason, the regional figures should be read as descriptive snapshots of exposure profiles, not as rankings or performance assessments.

5.4 Average per-portal vulnerability exposure by region

While the regional aggregation highlights substantial differences in the total number of detected vulnerability categories, these differences may be influenced by the uneven number of portals operating within each region. To mitigate this effect, Fig. 4 reports the average number of distinct vulnerability categories per portal, grouped by severity and aggregated at regional level.

This representation provides a normalised view of exposure, focusing on the typical portal within each region rather than on aggregate volumes. As expected, the resulting picture differs from that of absolute counts. Some regions with a high total number of findings exhibit more moderate per-portal averages, while others show comparatively higher mean exposure despite smaller portal populations.

The figure should not be interpreted as a ranking of regional security performance. Instead, it highlights differences in baseline configuration patterns at the level of individual portals, offering a complementary perspective to the aggregate regional distributions discussed above.

5.5 Prevalence of vulnerability categories across regions

Figure 5 summarises the regional distribution of top 10 vulnerability categories by reporting the percentage of analysed portals in which each issue is observed. Unlike the previous aggregations, this representation focuses explicitly on how widespread specific configuration patterns are within each region, rather than on their overall volume.

Several vulnerability categories appear with high prevalence across a large fraction of regions. In particular, missing HTTP security headers and incomplete cookie-related attributes affect a substantial share of portals in most regions. The recurrence of these issues across heterogeneous regional contexts suggests that they are not tied to isolated implementation errors, but rather to commonly adopted baseline configurations.

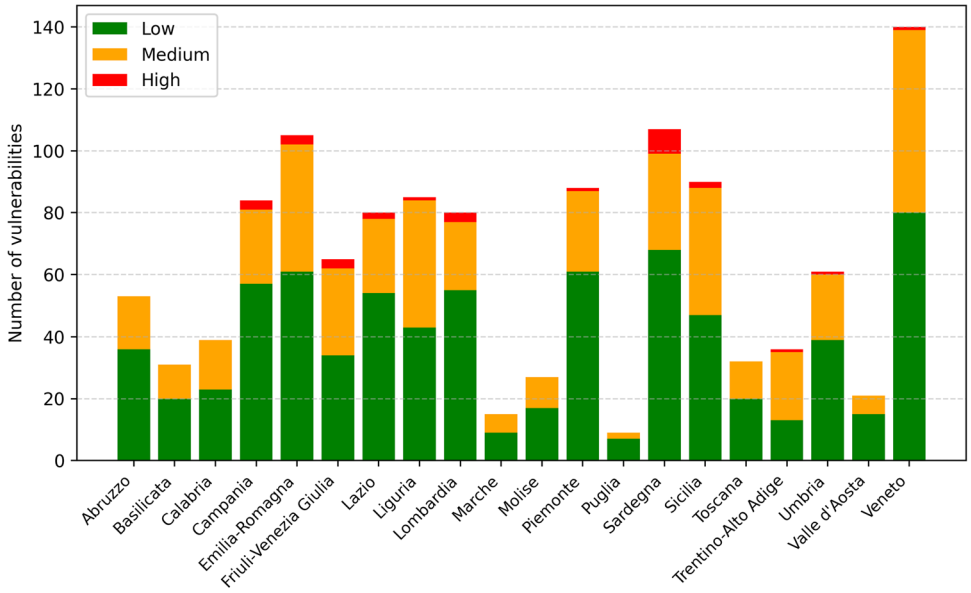


Fig. 3 Distribution of distinct vulnerability categories by region, grouped by severity

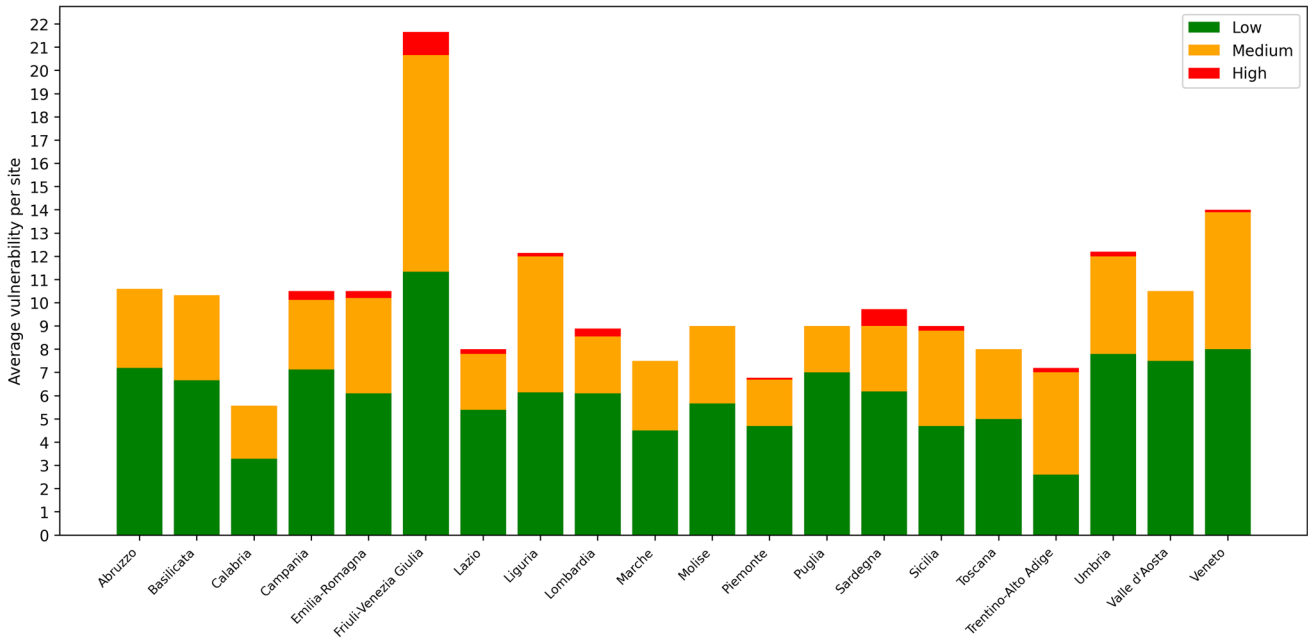


Fig. 4 Average number of distinct vulnerability categories per portal, grouped by severity and aggregated at regional level

Other categories display a more uneven distribution. Vulnerabilities related to cross-domain JavaScript inclusion, clickjacking protections, or server-side information disclosure show pronounced variation from one region to another, with some regions exhibiting high prevalence and others reporting little or no occurrence. These differences are consistent with the use of different application stacks, frameworks, and integration models at the regional level.

The heatmap does not convey information about exploitability or impact. Instead, it provides a comparative view of configuration prevalence, highlighting which defensive measures are routinely omitted and which are more selectively adopted across regions. As such, the figure is intended to support a descriptive assessment of recurring security patterns, rather than to imply risk levels or performance differences between regions.

5.5.1 Most frequent vulnerability categories by region

Alongside the prevalence heatmap, Table 2 reports the most frequent vulnerability categories observed in each region. The table provides a compact summary of the issues that most consistently appear across regional portals, complementing the visual overview offered in Fig. 5.

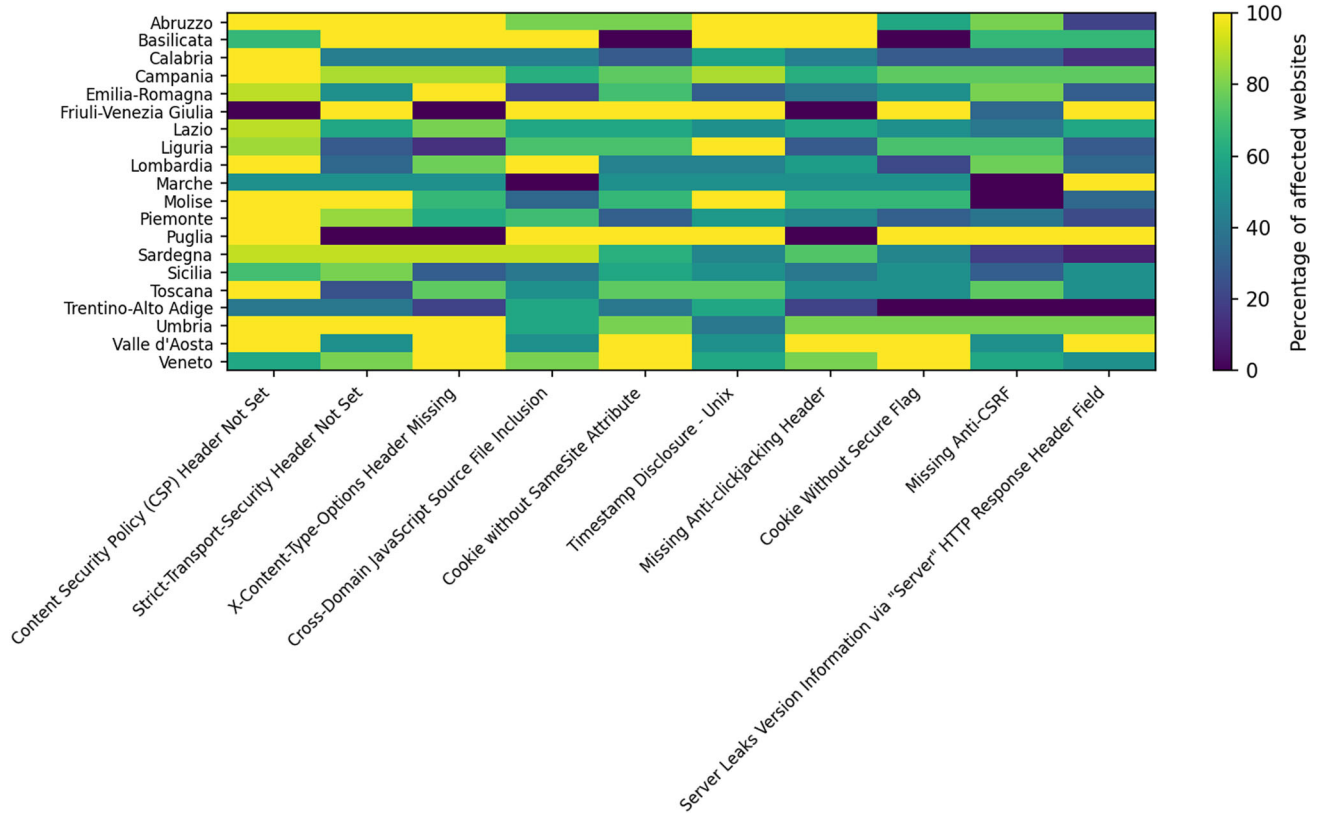


Fig. 5 Heatmap showing the percentage of analysed portals affected by each vulnerability category across regions

Across many regions, the same small set of vulnerability categories recurs among the most prevalent findings, particularly those related to missing HTTP security headers and incomplete client-side protections. This convergence reinforces the observation that a limited number of configuration patterns account for a substantial fraction of the observed exposure.

At the same time, regional differences remain visible in the composition of the top categories. In some regions, issues related to third-party integrations or script inclusion appear among the dominant findings, while in others they are largely absent. The table therefore helps distinguish between vulnerabilities that are broadly shared across regions and those that reflect more localised architectural choices.

5.6 Macro-area profiles of vulnerability categories

Figure 6 shows the dominant vulnerability-category profiles observed within each macro-area. The Northern macro-area is characterised by missing security headers and a comparatively higher prominence of cross-domain JavaScript inclusions, consistent with more heterogeneous and layered technology stacks. The Central macro-area shows a more balanced distribution across vulnerability categories, with no single class overwhelmingly dominating the profile. In the Southern macro-area, header-related misconfigurations remain prominent, while issues linked to external script inclusion appear less frequent.

Taken together, these profiles highlight differences in configuration practices and architectural complexity across macro-areas, reinforcing the picture of a nationally heterogeneous but structurally patterned security landscape.

5.7 Severity-weighted risk scores at portal level

Figure 7 shows the distribution of portal-level severity-weighted risk scores by macro-area. The distributions reveal substantial intra-area variability, with each macro-area including both low-exposure portals and higher-exposure outliers.

The Northern macro-area shows a slightly higher central tendency and wider dispersion, but elevated values are also present in the Centre and the South. This confirms that exposure is unevenly distributed within all macro-areas and does not follow a purely geographic pattern.

Portals with limited or no high-severity findings may still obtain relatively high scores when multiple medium-severity categories accumulate. This supports the use of aggregate exposure indicators alongside severity-specific counts.

Table 2 Most frequent vulnerability categories observed in each Italian region (presence-based counts)

	HTTP security headers				External scripts	Cookie attributes		Information disclosure		Request handling
Region	CSP	HSTS	XCTO	XFO	XJS	CS	CSEC	TS	XPB	CSRF
Abruzzo	5	5	5	5	4	4	3	5	3	4
Basilicata	2	3	3	3	3	0	0	3	2	2
Calabria	7	3	3	3	3	2	2	4	1	2
Campania	8	7	7	5	5	6	6	7	4	6
Emilia-Romagna	9	5	10	4	2	7	5	3	5	8
Friuli-Venezia Giulia	0	3	0	0	3	3	3	3	0	1
Lazio	9	6	8	6	6	6	5	5	4	4
Liguria	6	2	1	2	5	5	5	7	5	5
Lombardia	9	3	7	5	9	4	2	4	2	7
Marche	1	1	1	1	0	1	1	1	0	0
Molise	4	4	2	2	2	3	3	4	1	1
Piemonte	13	11	8	6	9	4	4	7	5	5
Puglia	1	0	0	0	1	1	1	1	0	1
Sardegna	10	10	10	8	10	7	5	5	7	2
Sicilia	8	9	3	4	5	7	6	5	5	3
Toscana	4	1	3	2	2	3	2	3	1	3
Trentino-Alto Adige	2	2	1	1	3	2	0	3	0	0
Umbria	5	5	5	4	3	4	4	2	2	4
Valle d'Aosta	2	1	2	2	1	2	2	1	1	1
Veneto	6	8	10	8	8	10	10	6	6	6

Acronyms follow the definitions reported in Table 1

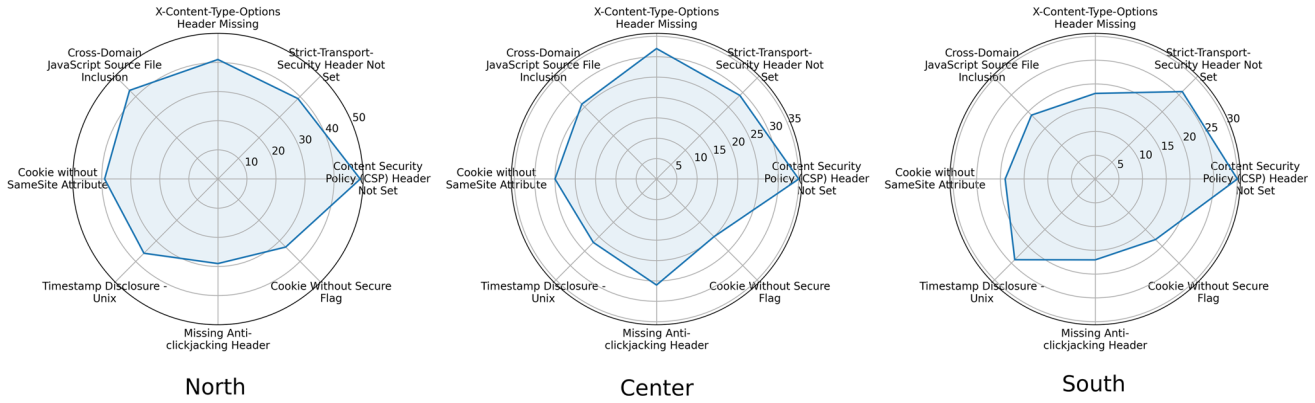


Fig. 6 Radar plots summarising the most prevalent vulnerability categories within each Italian macro-area

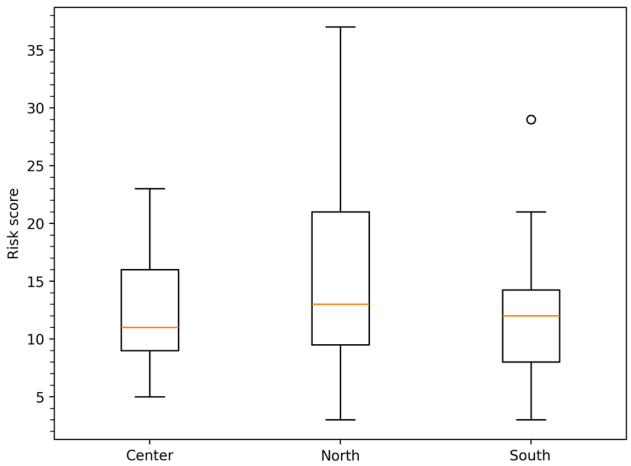


Fig. 7 Distribution of severity-weighted risk scores at portal level, grouped by macro-area

5.8 Descriptive statistics by region and macro-area

To complement the aggregate counts and graphical distributions reported above, Table 3 provides descriptive statistics at macro-area and regional levels. For each territorial group, the table reports the number of analysed portals and the median values with the corresponding interquartile interval for Low-, Medium-, and High-severity findings, as well as for the severity-weighted risk score.

At the macro-area level, the three distributions are relatively close in terms of central tendency, but they differ in dispersion. The North shows the highest median severity-weighted risk score, with a median of 13.0 and an interquartile interval of 9.5−21.0. The South follows with a median score of 12.0 [8.0−14.8], while the Centre reports a median score of 11.0 [9.0−16.0]. This indicates that the North has a slightly higher central tendency and a wider variability, but the overlap between interquartile intervals suggests that macro-area differences should be interpreted cautiously. In all macro-areas, the median number of High-severity findings is 0.0 [0.0−0.0], confirming that high-severity scanner-reported findings are not systematically present at the typical portal level.

The regional statistics reveal stronger heterogeneity than the macro-area summaries. Friuli-Venezia Giulia shows the highest median severity-weighted risk score, with 32.0 [31.5−34.0], together with the highest median values for Low- and Medium-severity findings, respectively 11.0 [10.5−12.0] and 9.0 [9.0−9.5]. However, this value is based on only three analysed portals and should therefore be interpreted as a localised pattern rather than as a general regional ranking. Other regions with comparatively high median risk scores include Veneto, with 21.5 [13.0−24.8], Liguria, with 21.0 [16.5−22.5], and Umbria, with 20.0 [12.0−21.0]. These regions combine relatively high Low- or Medium-severity medians with broader interquartile intervals, suggesting the coexistence of portals with different configuration profiles within the same regional context.

By contrast, some regions show lower median severity-weighted scores and more compact distributions. Calabria reports a median score of 8.0 [6.5−8.0], Piemonte 9.0 [6.0−10.0], Lazio 10.0 [8.3−13.0], and Trentino-Alto Adige 10.0 [7.0−15.0]. These values do not imply the absence of configuration weaknesses, but indicate a lower median breadth of scanner-reported categories in the analysed portals. Regions with very small portal counts, such as Puglia ($n = 1$), Marche ($n = 2$), Valle d'Aosta ($n = 2$), Basilicata ($n = 3$), and Friuli-Venezia Giulia ($n = 3$), require particular caution because their medians and interquartile intervals are strongly influenced by a limited number of observations.

The distribution of High-severity findings further supports the interpretation that such findings are sporadic rather than widespread. Friuli-Venezia Giulia is the only region with a median High-severity value of 1.0 [1.0−1.0]. In most other regions, the median remains 0.0, although the upper quartile is above zero in some cases, such as Sardegna 0.0 [0.0−2.0], Lombardia 0.0 [0.0−1.0], Emilia-Romagna 0.0 [0.0−0.8], and Campania 0.0 [0.0−0.3]. This pattern indicates that high-

severity scanner-reported findings occur in specific subsets of portals rather than characterising the typical portal in most regions.

Overall, Table 3 shows that variability within regions is at least as important as variability between macro-areas. The main empirical signal is therefore not a simple North–Centre–South gradient, but a heterogeneous national landscape in which specific regional ecosystems exhibit different combinations of Low-, Medium-, and occasional High-severity configuration signals. These descriptive statistics reinforce the interpretation that Italian public healthcare portals are characterised by uneven baseline configuration patterns rather than by a uniform national exposure profile.

5.9 Summary of key empirical findings

Across all aggregation levels considered in this study—portal, regional, and macro-area—the observed exposure is largely driven by a limited and recurring set of configuration-related vulnerability categories. Missing or incomplete security headers, cookie attribute misconfigurations, and basic client-side protections consistently account for a substantial fraction of the detected issues, regardless of geographic aggregation. High-severity findings, by contrast, do not exhibit clear geographic clustering and appear sporadically across regions and macro-areas.

The results presented in this section can be summarized as follows:

- Baseline hardening weaknesses—particularly related to HTTP security headers and cookie attributes—are widespread across the national healthcare portal ecosystem.
- Vulnerability presence varies considerably across regions, reflecting differences in technological stacks and organizational practices rather than simple geographical factors.
- Macro-areas exhibit distinct vulnerability profiles, with differences in architectural complexity and configuration uniformity.
- Severity-weighted risk scores reveal substantial variability both within and across macro-areas, indicating that exposure is unevenly distributed even when severity classifications are similar.

These empirical observations provide the foundation for the interpretative discussion that follows, where technical findings are contextualized in terms of governance, organizational constraints, and implications for public digital healthcare services.

Detailed per-portal results, including complete severity counts, risk scores, and detected technologies, are provided in Appendix A as supplementary material to support independent verification and reuse of the dataset.

6 Discussion

6.1 From vulnerability counts to baseline security posture

Before discussing individual findings, it is important to clarify how the adopted measurement approach shapes their interpretation. In this study, vulnerabilities are counted as distinct per portal, meaning that the presence of a given weakness is recorded once, regardless of how many pages or endpoints expose it. This choice shifts the focus away from frequency and towards structural exposure.

As a consequence, the results should be read as indicators of baseline security posture rather than as measures of attack likelihood or exploit success. A portal that exposes a vulnerability across many pages is not treated as inherently riskier than one where the same issue appears in a single location. Instead, both are considered to share the same underlying configuration or design gap. This perspective aligns with the goal of assessing how systematically certain defensive measures are adopted—or omitted—across the public healthcare web ecosystem.

This distinction is particularly relevant in a context where portal size, content volume, and architectural complexity vary substantially. By abstracting away from repetition, the analysis emphasises what kinds of weaknesses exist, not how often they manifest within a single system.

6.2 Interpreting the configuration profile of Italian public health portals

If one looks at the results without trying to force a strong narrative onto them, the overall vulnerability profile appears fairly unremarkable. There is no clear signal of widespread critical failures, nor evidence that a small set of severe issues dominates the landscape. What emerges instead is a collection of familiar, mostly low- to medium-severity weaknesses that recur across many portals, often in slightly different combinations.

This kind of distribution is typical of systems that have been operational for a long time. The portals analysed in this study generally appear functional and stable, and in many cases clearly maintained. At the same time, security-related configurations seem to have evolved unevenly. Some aspects reflect more recent practices, while others still follow older assumptions that were once acceptable but have not been systematically revisited.

The persistence of these issues does not necessarily indicate neglect. Rather, it suggests that security improvements

Table 3 Descriptive statistics of portal-level vulnerability exposure by macro-area and region

Area/region	*n*	Low	Medium	High	Risk score
Macro-area					
Centre	37	6.0 [4.0−8.0]	3.0 [2.0−4.0]	0.0 [0.0−0.0]	11.0 [9.0−16.0]
North	59	6.0 [4.0−8.5]	3.0 [2.0−6.0]	0.0 [0.0−0.0]	13.0 [9.5−21.0]
South	34	5.0 [4.0−7.0]	3.0 [2.0−4.8]	0.0 [0.0−0.0]	12.0 [8.0−14.8]
Region					
Abruzzo	5	7.0 [7.0−7.0]	4.0 [3.0−4.0]	0.0 [0.0−0.0]	15.0 [12.0−15.0]
Basilicata	3	7.0 [5.5−8.0]	3.0 [2.5−4.5]	0.0 [0.0−0.0]	13.0 [10.5−17.0]
Calabria	7	4.0 [3.0−4.0]	2.0 [1.5−2.0]	0.0 [0.0−0.0]	8.0 [6.5−8.0]
Campania	8	7.5 [5.8−8.3]	3.0 [2.8−3.3]	0.0 [0.0−0.3]	14.5 [12.8−16.3]
Emilia-Romagna	10	5.0 [5.0−6.0]	3.0 [2.3−3.8]	0.0 [0.0−0.8]	12.0 [10.3−13.5]
Friuli-Venezia Giulia	3	11.0 [10.5−12.0]	9.0 [9.0−9.5]	1.0 [1.0−1.0]	32.0 [31.5−34.0]
Lazio	10	5.0 [4.0−6.8]	2.0 [2.0−3.0]	0.0 [0.0−0.0]	10.0 [8.3−13.0]
Liguria	7	7.0 [4.5−7.5]	7.0 [5.0−7.0]	0.0 [0.0−0.0]	21.0 [16.5−22.5]
Lombardia	9	6.0 [5.0−6.0]	2.0 [2.0−3.0]	0.0 [0.0−1.0]	11.0 [10.0−13.0]
Marche	2	4.5 [3.8−5.3]	3.0 [2.5−3.5]	0.0 [0.0−0.0]	10.5 [10.3−10.8]
Molise	4	5.5 [4.8−6.5]	2.5 [2.0−3.5]	0.0 [0.0−0.0]	11.5 [10.8−12.5]
Piemonte	13	4.0 [3.0−7.0]	2.0 [1.0−3.0]	0.0 [0.0−0.0]	9.0 [6.0−10.0]
Puglia	1	7.0 [7.0−7.0]	2.0 [2.0−2.0]	0.0 [0.0−0.0]	11.0 [11.0−11.0]
Sardegna	11	6.0 [4.0−8.0]	2.0 [2.0−3.5]	0.0 [0.0−2.0]	11.0 [8.0−21.0]
Sicilia	11	4.0 [3.0−6.0]	5.0 [2.0−5.0]	0.0 [0.0−0.0]	13.0 [10.0−15.5]
Toscana	4	4.5 [3.0−6.5]	3.5 [2.5−4.0]	0.0 [0.0−0.0]	11.5 [9.5−13.0]
Trentino-Alto Adige	5	3.0 [2.0−3.0]	3.0 [3.0−6.0]	0.0 [0.0−0.0]	10.0 [7.0−15.0]
Umbria	5	9.0 [6.0−9.0]	4.0 [3.0−5.0]	0.0 [0.0−0.0]	20.0 [12.0−21.0]
Valle d'Aosta	2	7.5 [6.8−8.3]	3.0 [3.0−3.0]	0.0 [0.0−0.0]	13.5 [12.8−14.3]
Veneto	10	8.5 [7.0−9.0]	6.5 [5.0−7.8]	0.0 [0.0−0.0]	21.5 [13.0−24.8]

Values are reported as median [Q1–Q3]

tend to be introduced opportunistically, often in response to specific needs or constraints, instead of being applied uniformly across the entire application surface. As a result, the security posture of a portal becomes a composite of decisions made at different points in time, under different priorities.

Seen in this light, the vulnerability profiles observed here are less about individual flaws and more about how maintenance is actually carried out in public healthcare web services. Security is present, but not always treated as something that requires periodic consolidation.

6.3 Incomplete cross-site request forgery (CSRF) protections and transactional robustness

Among the recurring findings, the limited visibility of explicit Cross-Site Request Forgery (CSRF) protections deserves particular attention. CSRF refers to a class of attacks in which a user's authenticated browser session may be abused to trigger unintended state-changing requests. The prevalence analysis shows that a significant number of portals expose forms or state-changing endpoints without detectable CSRF tokens, a condition that appears across regions and macro-areas.

This result should not be overstated. Passive scanning cannot determine whether a given endpoint is actually exploitable, nor can it account for framework-level mitigations that may not be externally observable. In addition, not all affected forms are equally sensitive, and some may only support low-impact interactions. For these reasons, the absence of a detectable token should be interpreted with caution.

That said, the consistency of this pattern across a national-scale dataset suggests a more general issue. In complex web applications, transactional robustness relies on the combination of multiple defensive layers, including session handling, cookie attributes, and request validation. When Anti-CSRF mechanisms are missing or inconsistently applied, the overall robustness of state-changing operations becomes more dependent on assumptions about user behaviour and session context. These assumptions may hold in practice, but they reduce tolerance to unexpected interactions or to the presence of additional vulnerabilities.

From this perspective, the prevalence of missing Anti-CSRF protections is less about a single vulnerability class and more about the fragility of transactional workflows in environments that handle sensitive user interactions.

6.4 Technological obsolescence and the persistence of technical debt

The technology data collected during the analysis help explain why many of the same vulnerability categories continue to appear across otherwise different portals. A large portion of the analysed systems relies on technologies that have been in place for years and have gradually accumulated extensions, custom code, and third-party components.

In practice, obsolescence rarely takes the form of clearly "outdated" systems that are left untouched. More often, it shows up as partial ageing. Some components are updated, others are not, and over time these differences start to matter. Client-side libraries, auxiliary plugins, and configuration defaults are particularly prone to this kind of drift, because they tend to sit outside the core service logic and therefore attract less attention during routine maintenance.

Addressing this type of technical debt is not straightforward, especially in public-sector environments. Updating long-standing components can introduce compatibility issues, require coordination with external vendors, or trigger procurement and validation processes that are difficult to justify for changes that are not immediately visible to users. Under these conditions, postponing updates becomes a rational choice, even when the security implications are understood.

From this perspective, the continued presence of certain vulnerabilities should not be read as evidence that obsolete technologies are still being actively chosen. Rather, it reflects the difficulty of reworking systems that were designed to evolve gradually and that now carry the weight of many incremental decisions. The vulnerabilities observed in this study are therefore better interpreted as the by-product of long maintenance histories than as the result of poor technological choices in isolation.

6.5 Regional heterogeneity and uneven cyber maturity

The regional and macro-area analyses reveal a high degree of heterogeneity in vulnerability presence and severity-weighted risk scores. Some regions exhibit relatively uniform profiles across their portals, while others show wide internal variability, with both low-exposure and high-exposure systems coexisting within the same administrative context.

These differences should not be interpreted as straightforward indicators of regional performance. Instead, they point to uneven cyber maturity, shaped by factors such as governance models, levels of centralisation, historical development paths, and vendor ecosystems. Regions that have consolidated digital health services under a limited number of platforms may find it easier to enforce consistent security baselines, while more fragmented environments face greater coordination challenges.

At the macro-area level, differences appear more gradual than categorical. While northern regions tend to exhibit broader vulnerability profiles and higher dispersion of risk scores, similar patterns—albeit on a smaller scale—are also present in the Centre and the South. This suggests that exposure is driven more by architectural and organisational complexity than by geography alone.

6.6 Positioning the findings within the broader web-security landscape

The findings of this study should be interpreted within a broader empirical and operational context. From a web-security perspective, the uneven adoption of baseline controls is not unique to Italian public healthcare portals. Large-scale analyses of public websites have repeatedly shown that HTTP security headers and related browser-side protections are inconsistently deployed, even when the underlying controls are mature and widely documented. Studies on HTTP security headers across large web populations have examined mechanisms such as Content Security Policy, Strict-Transport-Security, X-Frame-Options, X-Content-Type-Options, and cookie-related protections, reporting substantial variability in their adoption [48, 49]. This is consistent with the dominant patterns observed in our dataset, where missing or incomplete security headers and cookie attributes account for a large share of the recurring findings.

The healthcare relevance of these patterns is reinforced by recent evidence on globally popular websites. In a large-scale assessment of HTTP security headers, healthcare websites were reported as one of the weakest categories in terms of average security score, despite the sensitivity of the data and services associated with the sector [49]. Although such studies do not focus specifically on institutional public healthcare portals or on the Italian National Health Service, they provide a useful comparative baseline: the weaknesses observed in our study reflect a broader difficulty in translating well-known web-hardening practices into consistent operational configurations.

At the sectoral level, these configuration signals should also be read against the healthcare threat landscape. ENISA identifies ransomware, data breaches, and availability-related disruptions as major concerns for the health sector, and recent ENISA material reports that ransomware and data breaches account for a substantial share of analysed health-sector incidents [50, 51]. The present study does not analyse incidents, exploit chains, or authenticated workflows. Nevertheless,

externally visible weaknesses such as information disclosure, inconsistent header deployment, externally loaded scripts, and incomplete request-protection mechanisms may contribute to reconnaissance exposure and may reduce the robustness of public-facing digital services.

European digital-health infrastructures further complicate this picture. Public healthcare portals increasingly operate within ecosystems that include electronic health records, booking services, payment systems, identity-management components, and cross-border health data exchange mechanisms. Prior work on the European cross-border health data exchange roadmap highlights the importance of interoperability, privacy, security, auditability, and governance in such environments, including in the Italian setting [52]. These broader requirements help explain why baseline portal hardening cannot be considered an isolated technical issue: it is part of a wider trust and resilience problem affecting digital health services.

The contribution of this work is therefore not to claim that Italian portals are uniquely insecure, but to show how a regulated and socially critical healthcare ecosystem reflects broader web-security challenges through measurable, presence-based configuration signals.

6.7 Implications for patient trust, compliance, and service resilience

Although the vulnerabilities identified in this study are largely configuration-related, their implications extend beyond technical considerations. Public healthcare portals mediate access to services that citizens increasingly rely on, from appointment booking to the retrieval of personal medical information. Perceived or actual weaknesses in these systems can therefore affect patient trust, particularly in a domain where confidentiality expectations are high.

From a regulatory perspective, the presence of widely known and well-documented weaknesses raises questions about alignment with the principle of "state of the art" security measures. While the identification of a vulnerability does not equate to non-compliance, the systematic omission of basic defensive controls may become problematic if left unaddressed over time.

Operationally, baseline weaknesses can also affect service resilience. Even in the absence of major breaches, minor security incidents or disruptions can undermine confidence and increase the burden on support and incident response teams. In healthcare contexts, where continuity of service is critical, these indirect effects are particularly relevant.

6.8 Methodological limitations and interpretative boundaries

The interpretation of these results must account for the inherent limitations of the adopted methodology. The analysis is based on passive scanning techniques, which are effective in identifying externally observable configuration patterns, but necessarily limited in scope. They do not capture application logic, internal trust boundaries, or context-dependent protections that may mitigate some of the detected issues.

Moreover, the analysis observes each portal from the perspective of an unauthenticated external client. As a consequence, vulnerabilities that only manifest after authentication, or that depend on specific user roles, remain outside the scope of this study. Similarly, internal monitoring, intrusion detection, and response capabilities—factors that strongly influence real-world risk—cannot be assessed through this approach.

Automated scans also introduce a degree of uncertainty. Some findings may correspond to false positives or to conditions that are intentionally accepted as trade-offs. Conversely, subtle logic flaws or workflow-specific weaknesses may go undetected. For these reasons, the results should be understood as indicative signals, not as definitive assessments of security posture.

Despite these constraints, the consistency of several patterns across a large and comprehensive dataset suggests that the findings are not artefacts of individual tools or configurations. Rather, they point to recurring characteristics of public healthcare web portals that warrant further investigation through complementary methods.

7 Conclusions

This study presented a nation-wide assessment of the baseline security posture of Italian public healthcare portals, based on a uniform passive analysis of all regional and provincial institutional websites. By focusing on the presence of distinct vulnerability categories rather than on their repetition across multiple pages, the analysis aimed to capture structural configuration patterns while avoiding biases related to portal size or complexity.

The results depict a landscape characterised by heterogeneity rather than by pervasive critical failures. Across regions and macro-areas, high-severity vulnerabilities appear infrequently, while low- and medium-severity issues account

for most of the observed exposure. Many of these issues relate to long-established defensive measures, such as HTTP security headers, cookie attributes, and basic request-handling protections, whose adoption remains uneven across otherwise functional and stable systems.

Rather than identifying isolated weak points, the analysis highlights recurring patterns that reflect how public healthcare portals evolve over time. Incremental development, layered architectures, and long maintenance histories contribute to environments in which security practices are applied selectively and revisited irregularly. In this sense, the observed vulnerabilities are best understood as indicators of configuration drift and accumulated technical debt, rather than as evidence of systematically insecure design.

The regional and macro-area perspectives further underscore the absence of a single explanatory factor. Differences in vulnerability presence and severity-weighted risk scores do not follow simple geographical or demographic lines, but instead suggest the influence of organisational structures, governance models, and technological choices. Even within the same administrative context, portals with markedly different exposure profiles coexist, reinforcing the view that cyber maturity is unevenly distributed.

Several limitations should be kept in mind when interpreting these findings. The analysis is restricted to externally observable characteristics and relies on passive scanning techniques, which cannot assess exploitability, internal controls, or operational security practices. As a result, the presence or absence of detected vulnerabilities should not be equated with actual risk levels. Nevertheless, the consistency of multiple patterns across a comprehensive national dataset indicates that the results capture meaningful aspects of the current security posture of public healthcare web services.

Overall, this work provides an empirical snapshot of how baseline security measures are currently reflected in Italian public healthcare portals. By offering a reproducible measurement framework and a consolidated view across regions, it contributes a reference point for future longitudinal analyses and for comparative studies in similar institutional contexts, without claiming to exhaustively characterise security risk or organisational performance.

Appendix A Supplementary Tables

See Tables 4 and 5.

Table 4 Per-portal severity counts and severity-weighted risk scores

Portal	Low	Medium	High	Risk score	Region	Macro-area
apss.tn.it	3	6	0	15	Trentino-Alto Adige	Northern
asfo.sanita.fvg.it	13	10	1	36	Friuli-Venezia Giulia	Northern
asufc.sanita.fvg.it	10	9	1	31	Friuli-Venezia Giulia	Northern
asugi.sanita.fvg.it	11	9	1	32	Friuli-Venezia Giulia	Northern
cup-portal.regione.molise.it	5	3	0	11	Molise	Southern
cup.apss.tn.it	3	9	0	21	Trentino-Alto Adige	Northern
cup.regione.umbria.it	4	2	0	8	Umbria	Center
cupweb.sardegnasalute.it	6	5	2	22	Sardegna	Center
fse.regione.molise.it	4	5	0	14	Molise	Southern
fse.sanita.marche.it	3	4	0	11	Marche	Center
fse.sardegnasalute.it	8	4	0	16	Sardegna	Center
fse.vda.it	6	3	0	12	Valle d'Aosta	Northern
mycupmarche.it	6	2	0	10	Marche	Center
prenota.regione.calabria.it	3	6	0	15	Calabria	Southern
prenota.sanita.toscana.it	3	1	0	5	Toscana	Center
prenotasalute.regione.lombardia.it	9	3	0	15	Lombardia	Northern
prenotasmart.regione.lazio.it	2	4	0	10	Lazio	Center
prenotosalute.regione.liguria.it	3	5	0	13	Liguria	Northern
salute.provincia.bz.it	4	3	0	10	Trentino-Alto Adige	Northern
salute.regione.emilia-romagna.it	14	5	1	27	Emilia-Romagna	Northern
salute.regione.umbria.it	6	3	0	12	Umbria	Center
salute.regione.veneto.it	12	8	0	28	Veneto	Northern
sanita.regione.abruzzo.it	9	4	0	17	Abruzzo	Center
sinfonia.regione.campania.it	3	2	0	7	Campania	Southern
sovracup.regione.sicilia.it	6	6	1	21	Sicilia	Southern
trec.trentinosalute.net	2	1	1	7	Trentino-Alto Adige	Northern
www.alisa.liguria.it	8	7	0	22	Liguria	Northern
www.asl.at.it	5	2	0	9	Piemonte	Northern
www.asl.fr.it	4	2	0	8	Lazio	Center
www.asl.novara.it	7	3	1	16	Piemonte	Northern
www.asl.pe.it	7	4	0	15	Abruzzo	Center
www.asl.rieti.it	10	3	0	16	Lazio	Center
www.asl1.liguria.it	7	7	0	21	Liguria	Northern
www.asl1abruzzo.it	7	4	0	15	Abruzzo	Center
www.asl2.liguria.it	6	7	0	20	Liguria	Northern
www.asl2abruzzo.it	6	3	0	12	Abruzzo	Center
www.asl3.liguria.it	7	8	0	23	Liguria	Northern
www.asl4.liguria.it	1	2	0	5	Liguria	Northern
www.asl5.liguria.it	11	5	1	24	Liguria	Northern
www.aslal.it	9	3	0	15	Piemonte	Northern
www.aslavellino.it	8	4	0	16	Campania	Southern
www.aslbenevento.it	5	2	2	15	Campania	Southern
www.aslbi.piemonte.it	2	1	0	4	Piemonte	Northern
www.aslcagliari.it	6	2	0	10	Sardegna	Center
www.aslcaserta.it	11	3	0	17	Campania	Southern

Table 4 continued

Portal	Low	Medium	High	Risk score	Region	Macro-area
www.aslcittaditorino.it	7	2	0	11	Piemonte	Northern
www.aslcn1.it	3	3	0	9	Piemonte	Northern
www.aslcn2.it	4	2	0	8	Piemonte	Northern
www.aslgallura.it	8	4	2	22	Sardegna	Center
www.aslmediocampidano.it	9	3	2	21	Sardegna	Center
www.aslnapoli1centro.it	9	4	1	20	Campania	Southern
www.aslnapoli2nord.it	8	3	0	14	Campania	Southern
www.aslnapoli3sud.it	7	3	0	13	Campania	Southern
www.aslnuoro.it	4	2	0	8	Sardegna	Center
www.aslogliastra.it	9	3	2	21	Sardegna	Center
www.asloristano.it	4	2	0	8	Sardegna	Center
www.aslroma1.it	6	2	0	10	Lazio	Center
www.aslroma2.it	5	2	0	9	Lazio	Center
www.aslroma3.it	7	3	1	16	Lazio	Center
www.aslroma4.it	8	1	0	10	Lazio	Center
www.aslroma5.it	4	2	0	8	Lazio	Center
www.aslroma6.it	3	2	0	7	Lazio	Center
www.aslsalerno.it	6	3	0	12	Campania	Southern
www.aslsassari.it	3	2	0	7	Sardegna	Center
www.aslsulcis.it	4	2	0	8	Sardegna	Center
www.aslteramo.it	7	2	0	11	Abruzzo	Center
www.aslto3.piemonte.it	7	1	0	9	Piemonte	Northern
www.aslto4.piemonte.it	4	1	0	6	Piemonte	Northern
www.aslto5.piemonte.it	2	2	0	6	Piemonte	Northern
www.aslvc.piemonte.it	4	3	0	10	Piemonte	Northern
www.aslvco.it	1	1	0	3	Piemonte	Northern
www.asmbasilicata.it	4	2	0	8	Basilicata	Southern
www.asp.cl.it	4	5	0	14	Sicilia	Southern
www.asp.cosenza.it	3	1	0	5	Calabria	Southern
www.asp.crotone.it	4	2	0	8	Calabria	Southern
www.asp.cz.it	4	2	0	8	Calabria	Southern
www.asp.messina.it	6	2	0	10	Sicilia	Southern
www.asp.rg.it	3	2	1	10	Sicilia	Southern
www.asp.sr.it	2	2	0	6	Sicilia	Southern
www.aspag.it	4	1	0	6	Sicilia	Southern
www.aspbasilicata.it	9	6	0	21	Basilicata	Southern
www.aspct.it	2	5	0	12	Sicilia	Southern
www.aspenna.it	6	4	0	14	Sicilia	Southern
www.asppalermo.org	3	5	0	13	Sicilia	Southern
www.asprc.it	4	2	0	8	Calabria	Southern
www.asptrapani.it	11	9	0	29	Sicilia	Southern

Table 4 continued

Portal	Low	Medium	High	Risk score	Region	Macro-area
www.aspvv.it	1	1	0	3	Calabria	Southern
www.asrem.molise.it	8	2	0	12	Molise	Southern
www.ats-bg.it	6	2	1	13	Lombardia	Northern
www.ats-brescia.it	6	2	1	13	Lombardia	Northern
www.ats-brianza.it	5	3	0	11	Lombardia	Northern
www.ats-insubria.it	6	2	0	10	Lombardia	Northern
www.ats-milano.it	9	3	1	18	Lombardia	Northern
www.ats-montagna.it	4	3	0	10	Lombardia	Northern
www.ats-pavia.it	5	2	0	9	Lombardia	Northern
www.ats-valpadana.it	5	2	0	9	Lombardia	Northern
www.aulss1.veneto.it	9	2	0	13	Veneto	Northern
www.aulss2.veneto.it	8	7	0	22	Veneto	Northern
www.aulss3.veneto.it	3	5	0	13	Veneto	Northern
www.aulss4.veneto.it	3	5	0	13	Veneto	Northern
www.aulss5.veneto.it	9	6	0	21	Veneto	Northern
www.aulss6.veneto.it	9	8	0	25	Veneto	Northern
www.aulss7.veneto.it	7	7	1	24	Veneto	Northern
www.aulss8.veneto.it	7	2	0	11	Veneto	Northern
www.aulss9.veneto.it	13	9	0	31	Veneto	Northern
www.ausl.bologna.it	6	2	0	10	Emilia-Romagna	Northern
www.ausl.fe.it	5	3	1	14	Emilia-Romagna	Northern
www.ausl.mo.it	9	14	0	37	Emilia-Romagna	Northern
www.ausl.pc.it	5	2	1	12	Emilia-Romagna	Northern
www.ausl.pr.it	6	3	0	12	Emilia-Romagna	Northern
www.ausl.re.it	5	3	0	11	Emilia-Romagna	Northern
www.ausl.vda.it	9	3	0	15	Valle d'Aosta	Northern
www.auslromagna.it	2	3	0	8	Emilia-Romagna	Northern
www.cupweb.it	5	2	0	9	Emilia-Romagna	Northern
www.fascicolo-sanitario.it	4	4	0	12	Emilia-Romagna	Northern
www.fascicolosanitario.regione.calabria.it	4	2	0	8	Calabria	Southern
www.regione.sicilia.it	7	5	0	17	Sicilia	Southern
www.sabes.it	1	3	0	7	Trentino-Alto Adige	Northern
www.salute.basilicata.it	7	3	0	13	Basilicata	Southern
www.salutelazio.it	5	3	1	14	Lazio	Center
www.salutepiemonte.it	6	2	0	10	Piemonte	Northern
www.sanita.puglia.it	7	2	0	11	Puglia	Southern
www.sardegnasalute.it	7	2	0	11	Sardegna	Center
www.umbriasalute.com	9	7	0	23	Umbria	Center
www.uslcentro.toscana.it	8	4	0	16	Toscana	Center
www.uslnordovest.toscana.it	3	4	0	11	Toscana	Center
www.uslsudest.toscana.it	6	3	0	12	Toscana	Center
www.uslumbria1.it	9	4	1	20	Umbria	Center
www.uslumbria2.it	11	5	0	21	Umbria	Center
www3.regione.molise.it	6	2	0	10	Molise	Southern

Table 5 Detected technologies for public health portals

Site	Technologies
apss.tn.it	Bootstrap, Varnish, jQuery
asfo.sanita.fvg.it	Bootstrap, DataTables, Java, OpenCms, jQuery
asufc.sanita.fvg.it	Bootstrap, Cart Functionality, DataTables, Java, OpenCms, jQuery
asugi.sanita.fvg.it	Bootstrap, DataTables, Java, OpenCms, jQuery
cup-portal.regione.molise.it	Apache, Apache Tomcat, CentOS, Java, OpenSSL, mod_jk
cup.apss.tn.it	AngularJS, Nginx
cup.regione.umbria.it	Google Cloud, Nginx
cupweb.sardegnasalute.it	Bootstrap, Cloudflare, Font Awesome, Liferay, Modernizr, Moment.js, jQuery, jQuery Migrate
fse.regione.molise.it	Not detected
fse.sanita.marche.it	Nginx
fse.sardegnasalute.it	Cloudflare, Google Tag Manager
fse.vda.it	Bootstrap, Nginx, jQuery
mycupmarche.it	Apache Tomcat, Java
prenota.regione.calabria.it	Cloudflare
prenotasalute.regione.lombardia.it	Not detected
prenotasmart.regione.lazio.it	AngularJS, Google Font API
prenotosalute.regione.liguria.it	Nginx, jQuery
salute.provincia.bz.it	Not detected
salute.regione.emilia-romagna.it	IIS, Leaflet, Microsoft ASP.NET, Plone, Python, Varnish, Windows Server
salute.regione.umbria.it	Google Font API, Liferay, Modernizr, jQuery
salute.regione.veneto.it	Amazon Cloudfront, Amazon Web Services, Drupal, PHP
sanita.regione.abruzzo.it	Not detected
sinfonia.regione.campania.it	Not detected
sovracup.regione.sicilia.it	Bootstrap, Express, Font Awesome, Node.js, Underscore.js, jQuery
trec.trentinosalute.net	Bootstrap, Font Awesome, Google Font API, OpenLayers, jQuery, reCAPTCHA
www.alisa.liguria.it	Bootstrap, Font Awesome, IIS, Joomla, Microsoft ASP.NET, PHP, Windows Server, jQuery
www.asl.at.it	AddToAny, Bootstrap, Cart Functionality, Chart.js, Font Awesome, Lightbox, LiteSpeed, Modernizr, MySQL, OWL Carousel, PHP, Swiper Slider, Underscore.js, WordPress, Yoast SEO, animate.css, jQuery, jQuery Migrate, prettyPhoto
www.asl.fr.it	Bootstrap, MySQL, Nginx, PHP, Redis, Redis Object Cache, Slick, SweetAlert2, Underscore.js, Varnish, WordPress, Yoast SEO, jQuery, jQuery Migrate, jsDelivr, reCAPTCHA
www.asl.novara.it	Apache, Drupal, PHP
www.asl.pe.it	Apache, Bootstrap, Font Awesome, jQuery, jQuery Migrate
www.asl.rieti.it	Not detected
www.asl1.liguria.it	Apache, Bootstrap, Font Awesome, Joomla, PHP, jQuery
www.asl1abruzzo.it	Bootstrap, Font Awesome, Nginx, Plesk, Varnish, animate.css, jQuery, jQuery UI
www.asl2.liguria.it	Apache, Bootstrap, Cart Functionality, Font Awesome, Joomla, PHP, jQuery

Table 5 continued

Site	Technologies
www.asl2abruzzo.it	Lightbox, MySQL, Nginx, PHP, Underscore.js, Varnish, WordPress, WordPress Super Cache, Yoast SEO, jQuery
www.asl3.liguria.it	Apache, Bootstrap, Cart Functionality, Font Awesome, Joomla, PHP, jQuery
www.asl4.liguria.it	Apache, Cart Functionality, Modernizr, MySQL, PHP, WordPress, Yoast SEO, jQuery
www.asl5.liguria.it	Bootstrap, Cart Functionality, DNN, IIS, Microsoft ASP.NET, Modernizr, Windows Server, jQuery, jQuery Migrate, jQuery UI
www.aslal.it	Not detected
www.aslavellino.it	Apache, Bootstrap, Cart Functionality, Font Awesome, Google Font API, Joomla, OpenSSL, Osano, PHP, Semantic-ui, animate.css, jQuery, jQuery Migrate
www.aslbenevento.it	Not detected
www.aslbi.piemonte.it	Cart Functionality, Google Font API, MySQL, Nginx, PHP, W3 Total Cache, WordPress, Yoast SEO
www.aslcagliari.it	Bootstrap, Cloudflare, MySQL, OWL Carousel, PHP, WordPress, Yoast SEO, jQuery, jQuery UI
www.aslcaserta.it	Not detected
www.aslcittaditorino.it	Cart Functionality, MySQL, Nginx, PHP, W3 Total Cache, WordPress
www.aslcn1.it	Apache, Bootstrap, OWL Carousel, Open Web Analytics, PHP, TYPO3 CMS, jQuery
www.aslcn2.it	Apache, Cart Functionality, MySQL, PHP, WordPress, jQuery, jQuery Migrate
www.aslgallura.it	AngularJS, Bootstrap, Cloudflare, Font Awesome, Material Design Lite, MySQL, OWL Carousel, PHP, WordPress, Yoast SEO, jQuery, jQuery UI
www.aslmediocampidano.it	AngularJS, Bootstrap, Cloudflare, Font Awesome, Material Design Lite, MySQL, OWL Carousel, PHP, WordPress, Yoast SEO, jQuery, jQuery UI
www.aslnapoli1centro.it	Not detected
www.aslnapoli2nord.it	Not detected
www.aslnapoli3sud.it	Apache, Bootstrap, Font Awesome, Google Font API, OpenSSL, jQuery, jsDelivr
www.aslnuoro.it	Not detected
www.aslogliastra.it	AngularJS, Bootstrap, Cloudflare, Font Awesome, Material Design Lite, MySQL, OWL Carousel, PHP, WordPress, Yoast SEO, jQuery, jQuery UI
www.asloristano.it	Bootstrap, Cloudflare, Material Design Lite, MySQL, OWL Carousel, PHP, WordPress, Yoast SEO, jQuery, jQuery UI
www.aslroma1.it	Cart Functionality, Nginx, PHP, Stimulus, reCAPTCHA
www.aslroma3.it	Apache, Elementor, Font Awesome, Google Font API, MySQL, OpenSSL, PHP, Red Hat, Slick, WordPress, Yoast SEO, jQuery, jQuery Migrate, prettyPhoto
www.aspbasilicata.it	Apache, Apache Tomcat, Bootstrap, CentOS, Font Awesome, Java, MySQL, OWL Carousel, OpenSSL, PHP, WordPress, WordPress Super Cache, Yoast SEO, YouTube, jQuery, jQuery Migrate, mod_jk

Table 5 continued

Site	Technologies
www.aspct.it	Not detected
www.aspenna.it	Not detected
www.asppalermo.org	Not detected
www.asprc.it	Bootstrap, Cart Functionality, jQuery
www.asptrapani.it	Bootstrap, Font Awesome, IIS, Microsoft ASP.NET, Windows Server, jQuery, jQuery UI
www.aspvv.it	Cloudflare
www.asrem.molise.it	Not detected
www.ats-bg.it	Drupal, Google Font API, Nginx, PHP
www.ats-brescia.it	Drupal, Google Font API, Nginx, PHP
www.aulss2.veneto.it	jQuery
www.aulss3.veneto.it	Hammer.js, Leaflet, Varnish
www.aulss4.veneto.it	Hammer.js, Leaflet, Varnish
www.aulss5.veneto.it	IIS, Microsoft ASP.NET, Windows Server, jQuery
www.aulss6.veneto.it	Cart Functionality, IIS, Microsoft ASP.NET, Windows Server, jQuery
www.aulss7.veneto.it	IIS, Microsoft ASP.NET, Windows Server, jQuery
www.aulss9.veneto.it	Bootstrap, DataTables, FancyBox, Font Awesome, IIS, Microsoft ASP.NET, OWL Carousel, Windows Server, animate.css, jQuery
www.ausl.bologna.it	Bootstrap, jQuery
www.ausl.fe.it	Apache, Cart Functionality, Debian, Plone, Python, React, Varnish
www.ausl.mo.it	Cart Functionality, MySQL, Nginx, PHP, W3 Total Cache, WordPress, animate.css
www.ausl.pc.it	Apache, Cart Functionality, Debian, Plone, Python, React, Varnish
www.ausl.pr.it	Not detected
www.ausl.re.it	Apache, Apache Tomcat, Bootstrap, Java, OWL Carousel, OpenSSL, jQuery, mod_jk
www.regione.calabria.it	Bootstrap, Cloudflare, MySQL, PHP, Slick, WordPress, Yoast SEO, jQuery
www.regione.campania.it	Apache, Bootstrap, Cart Functionality, CentOS, DataTables, Google Font API, SWFObject, jQuery, jQuery Migrate, jQuery UI
www.regione.fvg.it	Bootstrap, Cart Functionality, Font Awesome, Java, OWL Carousel, OpenCms, YouTube, jQuery
www.regione.lombardia.it	Not detected
www.regione.marche.it	Google Cloud, hCaptcha
www.regione.piemonte.it	Apache
www.regione.sicilia.it	Drupal, PHP
www.regione.toscana.it	Not detected
www.regione.vda.it	Cart Functionality, IIS, Microsoft ASP.NET, Windows Server, YouTube, jQuery, jQuery UI
www.sabes.it	Not detected
www.salute.basilicata.it	Apache, Bootstrap, Elementor, Font Awesome, MySQL, OWL Carousel, OpenSSL, PHP, Slick, UserWay, WordPress, Yoast SEO, jQuery, jQuery Migrate

Table 5 continued

Site	Technologies
www.salutelazio.it	Bootstrap, Google Font API, Lodash, jQuery, jsDelivr
www.salutepiemonte.it	Apache
www.sanita.puglia.it	Apache, Bootstrap, Leaflet, Lodash, OWL Carousel, jQuery
www.sardegnasalute.it	Apache, Cart Functionality, jQuery, jQuery Migrate
www.umbriasalute.com	Bootstrap, Font Awesome, Google Font API, Google Tag Manager, IIS, Microsoft ASP.NET, Modernizr, Windows Server, jQuery, jQuery UI
www.uslcentro.toscana.it	Apache, Joomla, MooTools, PHP, Ubuntu, jQuery, jQuery Migrate
www.uslnordovest.toscana.it	Not detected
www.uslsudest.toscana.it	Not detected
www.uslumbria1.it	Not detected
www.uslumbria2.it	Cart Functionality, FancyBox, Font Awesome, IIS, Microsoft ASP.NET, Windows Server, jQuery
www3.regione.molise.it	Not detected

Acknowledgements This research was co-funded by the Project "European Digital Innovation Hub for Secure Digital Transformation EDIH4DT"—Next Generation EU (PNRR)—M4C2I2.3)—CUP B97H22004920001. This research was co-funded by the Italian Complementary National Plan PNC-I.1 "Research initiatives for innovative technologies and pathways in the health and welfare sector" D.D. 931 of 06/06/2022, "DARE—DigitAl lifelong pRevEntion" initiative, code PNC0000002, CUP: B53C22006450001. **Use of Generative AI:** The authors declare that no generative AI was used in the writing of the paper.

Author Contributions All authors contributed equally to this work

Funding Open access funding provided by Università degli Studi di Bari Aldo Moro within the CRUI-CARE Agreement.

Data Availability Data will be provided on request

Declarations

Conflict of interest The authors declare that they have no known competing financial interests or personal relationships that could have appeared to influence the work reported in this paper.

Open Access This article is licensed under a Creative Commons Attribution 4.0 International License, which permits use, sharing, adaptation, distribution and reproduction in any medium or format, as long as you give appropriate credit to the original author(s) and the source, provide a link to the Creative Commons licence, and indicate if changes were made. The images or other third party material in this article are included in the article's Creative Commons licence, unless indicated otherwise in a credit line to the material. If material is not included in the article's Creative Commons licence and your intended use is not permitted by statutory regulation or exceeds the permitted use, you will need to obtain permission directly from the copyright holder. To view a copy of this licence, visit http://creativecommons.org/licenses/by/4.0/.

References

1. Cappa, C., Figoli, M., Rossi, P.: Network of services facilitating and supporting job placement for people with autism spectrum disorders. the experience of the asl piacenza, italy. Annali dell. Istit. Super. Sanità **56**(2), 241–246 (2020)
2. Piane, M., Bianco, L., Mancini, R., Fornelli, P., Gabriele, A., Medici, F., Battista, C., Greco, S., Croce, G., Franceschetti, L.: Impact of the covid-19 pandemic on clinical pathways for non-sars-cov-2 related diseases in the Lazio region, Italy. Int. J. Environ. Res. Public Health **19**(2), 635 (2022)
3. Coppolino, L., Sgaglione, L., D'Antonio, S., Magliulo, M., Romano, L., Pacelli, R.: Risk assessment driven use of advanced siem technology for cyber protection of critical e-health processes. SN Comput. Sci. **3**(1), 16 (2022)
4. European Union: Regulation (EU) 2016/679 (General Data Protection Regulation). https://eur-lex.europa.eu/legal-content/IT/TXT/PDF/?uri=CELEX:32016R0679. Accessed: 2026-08-24 (2016)
5. European Union: Directive (EU) 2022/2555 (NIS2 Directive). https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=CELEX:32022L2555 (2022). Accessed 24 Aug 2026
6. AgID: Misure minime di sicurezza ICT per le Pubbliche Amministrazioni. https://www.agid.gov.it/ (2017). Accessed 24 Aug 2026
7. Agenzia per l'Italia Digitale: Raccomandazioni AgID su TLS e Cipher Suite. https://www.agid.gov.it/it/sicurezza/tls-e-cipher-suite (2020). Accessed 24 Aug 2026
8. Agenzia per l'Italia Digitale: Linee guida per lo sviluppo del Software Sicuro. https://www.agid.gov.it/it/sicurezza/cert-pa/linee-guida-sviluppo-del-software-sicuro (2017). Accessed 24 Aug 2026
9. Caniglia, A., Dentamaro, V., Galantucci, S., Impedovo, D.: Fobics: assessing project security level through a metrics framework that evaluates devsecops performance. Inf. Softw. Technol. **178**, 107605 (2025)
10. European Commission: Report on cybersecurity and resiliency of Europes communications infrastructures. https://ec.europa.eu/newsroom/dae/redirection/document/102529. Accessed 24 Aug 2026
11. Cross, D.A., Levin, Z., Raj, M.: Patient portal use, perceptions of electronic health record value, and self-rated primary care quality among older adults: cross-sectional survey. J. Med. Int. Res. **23**(5), 22549 (2021)

12. Yusuf, M.K., Danladi, A.J., Shombot, E., Dusserre, G., Odey, V.A., Baba-Ahmed, N.B., Bestak, R., Lawan, M.I.: The growing cybersecurity crisis in healthcare: a call to action. AJISE **3**(3), 55–68 (2024)
13. Son, H., Nahm, E.-S., Zhu, S., Galik, E., Seidl, K.L., Castle, B., Russomanno, V.: Testing a model of patient portal use in adult patients. J. Nurs. Scholarsh. **53**(2), 143–153 (2021)
14. Kisekka, V., Goel, S., Williams, K.: Disambiguating between privacy and security in the context of health care: new insights on the determinants of health technologies use. Cyberpsychol. Behav. Soc. Netw. **24**(9), 617–623 (2021)
15. Norman, C.D., Skinner, H.A.: ehealth literacy: essential skills for consumer health in a networked world. J. Med. Int. Res. **8**(2), 9 (2006). https://doi.org/10.2196/jmir.8.2.e9
16. Liu, S.K., Osborn, A.E., Bell, S., Mecchella, J.N., Hort, S., Batsis, J.A.: Patient characteristics and utilization of an online patient portal in a rural academic general internal medicine practice. BMC Med. Inform. Decis. Mak. **22**(1), 42 (2022)
17. European Union: Regulation (EU) 2016/679 (General Data Protection Regulation). https://eur-lex.europa.eu/eli/reg/2016/679 (2016). Accessed 24 Aug 2026
18. European Union: Directive (EU) 2022/2555 on measures for a high common level of cybersecurity (NIS2). https://eur-lex.europa.eu/eli/dir/2022/2555 (2022). Accessed 24 Aug 2026
19. Arends, R., et al.: DNS security introduction and requirements. https://www.rfc-editor.org/rfc/rfc4033 (2005). Accessed 24 Aug 2026
20. Rescorla, E.: The transport layer security (TLS) protocol Version 1.3. https://www.rfc-editor.org/rfc/rfc8446 (2018). Accessed 24 Aug 2026
21. Castagno, M., et al.: The TLS multiple certificate status request extension. https://www.rfc-editor.org/rfc/rfc6961 (2013). Accessed 24 Aug 2026
22. Center for Internet Security: CIS benchmarks. https://www.cisecurity.org/cis-benchmarks (2024). Accessed 24 Aug 2026
23. OWASP Foundation: OWASP top ten: the ten most critical web application security risks. https://owasp.org/www-project-top-ten/ (2021). Accessed 24 Aug 2026
24. OWASP Foundation: OWASP API security top ten. https://owasp.org/www-project-api-security/ (2023). Accessed 24 Aug 2026
25. International Organization for Standardization: ISO/IEC 27001:2022 Information security, cybersecurity and privacy protection. https://www.iso.org/standard/82875.html (2022). Accessed 24 Aug 2026
26. International Organization for Standardization: ISO/IEC 27002:2022 Information security controls. https://www.iso.org/standard/75652.html (2022). Accessed 24 Aug 2026
27. European Union Agency for Cybersecurity: ENISA threat landscape report. https://www.enisa.europa.eu/topics/cyber-threats (2023). Accessed 24 Aug 2026
28. AgID: Linee guida per la sicurezza ICT e per lo sviluppo dei servizi digitali della PA. https://www.agid.gov.it/ (2022). Accessed 24 Aug 2026
29. Sheffer, Y., Saint-Andre, P., Fossati, T.: Recommendations for secure use of transport layer security (TLS) and datagram transport layer security (DTLS). https://www.rfc-editor.org/rfc/rfc9325 (2022). Accessed 24 Aug 2026
30. W3C: Content security policy Level 3. https://www.w3.org/TR/CSP3/ (2021). Accessed 24 Aug 2026
31. OWASP Foundation: OWASP cheat sheet series: content security policy. https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html (2023). Accessed 24 Aug 2026
32. OWASP Foundation: OWASP cheat sheet series: session management. https://cheatsheetseries.owasp.org/cheatsheets/Session_Management_Cheat_Sheet.html (2023). Accessed 24 Aug 2026
33. OWASP Foundation: OWASP cheat sheet series: HTML5 security (Cross-origin resource sharing). https://cheatsheetseries.owasp.org/cheatsheets/HTML5_Security_Cheat_Sheet.html (2023). Accessed 24 Aug 2026
34. W3C: Subresource integrity. https://www.w3.org/TR/SRI/ (2016). Accessed 24 Aug 2026
35. European Union Agency for Cybersecurity: ENISA threat landscape. https://www.enisa.europa.eu/topics/cyber-threats (2023). Accessed 24 Aug 2026
36. Kucherawy, M., Zwicky, T.: Domain-based message authentication, reporting, and conformance (DMARC). https://www.rfc-editor.org/rfc/rfc7489 (2022). Accessed 24 Aug 2026
37. Kitterman, S.: Sender policy framework (SPF) for authorizing use of domains in Email. https://www.rfc-editor.org/rfc/rfc7208 (2014). Accessed 24 Aug 2026
38. Crocker, D., Hansen, T., Kucherawy, M.: DomainKeys identified mail (DKIM) signatures. https://www.rfc-editor.org/rfc/rfc6376 (2011). Accessed 24 Aug 2026
39. Cloudflare: Cloudflare web application firewall documentation. https://developers.cloudflare.com/waf/ (2024). Accessed 24 Aug 2026
40. Akamai Technologies: Akamai Kona site defender: technical overview. https://www.akamai.com/ (2023). Accessed 24 Aug 2026
41. Foudil, E., Shafranovich, Y.: A file format to aid in security vulnerability disclosure. https://www.rfc-editor.org/rfc/rfc9116 (2022). Accessed 24 Aug 2026
42. OWASP Foundation: OWASP cheat sheet series: HTTP strict transport security. https://cheatsheetseries.owasp.org/cheatsheets/HTTP_Strict_Transport_Security_Cheat_Sheet.html (2025). Accessed 24 Aug 2026
43. OWASP Foundation: OWASP cheat sheet series: HTTP headers. https://cheatsheetseries.owasp.org/cheatsheets/HTTP_Headers_Cheat_Sheet.html (2025). Accessed 24 Aug 2026
44. OWASP Foundation: OWASP cheat sheet series: clickjacking defense. https://cheatsheetseries.owasp.org/cheatsheets/Clickjacking_Defense_Cheat_Sheet.html (2025). Accessed 24 Aug 2026
45. OWASP Foundation: OWASP cheat sheet series: cross-site request forgery prevention. https://cheatsheetseries.owasp.org/cheatsheets/Cross-Site_Request_Forgery_Prevention_Cheat_Sheet.html (2025). Accessed 24 Aug 2026
46. OWASP Foundation: OWASP cheat sheet series: third party JavaScript management. https://cheatsheetseries.owasp.org/cheatsheets/Third_Party_Javascript_Management_Cheat_Sheet.html (2025). Accessed 24 Aug 2026
47. OWASP Foundation: OWASP web security testing guide, Version 4.2. https://owasp.org/www-project-web-security-testing-guide/ (2020). Accessed 24 Aug 2026
48. Lavrenovs, A., Melón, F.J.R.: Http security headers analysis of top one million websites. In: 10th International Conference on Cyber Conflict (CyCon), pp. 345–370. (2018). https://doi.org/10.23919/CYCON.2018.8405025
49. Kishnani, U., Das, S.: Securing the web: analysis of HTTP security headers in popular global websites. arXiv preprint arXiv:2410.14924. Preprint (2024)
50. European union agency for cybersecurity: ENISA threat landscape: health sector. Technical report, ENISA. https://www.enisa.europa.eu/publications/health-threat-landscape (2023). Accessed 24 Aug 2026
51. European Union agency for cybersecurity: cybersecurity of critical sectors: health. https://www.enisa.europa.eu/topics/cybersecurity-of-critical-sectors/health (2024). Accessed 24 Aug 2026
52. Nalin, M., Baroni, I., Faiella, G., Romano, M.R., Matrisciano, F., Gelenbe, E., Martinez, D.M., Dumortier, J., Natsiavas, P., Votis, K., Koutkias, V., Tzovaras, D., Clemente, F.: The european cross-

border health data exchange roadmap: case study in the italian setting. J. Biomed. Inform. **94**, 103183 (2019). https://doi.org/10.1016/j.jbi.2019.103183
53. Di Pietro, R., Lombardi, F., Signorini, M.: Technology for trusted cloud security: survey and open issues. In: Cloud Computing Security, pp. 357–372. CRC Press, ??? (2020)
54. Laperdrix, P., Bielova, N., Baudry, B., Avoine, G.: Browser fingerprinting: a survey. ACM Trans. Web **14**(2), 1–33 (2020)
55. Senol, A., Acar, G.: Unveiling the impact of user-agent reduction and client hints: a measurement study. In: Proceedings of the 22nd Workshop on Privacy in the Electronic Society, pp. 91–106. (2023)
56. Bujlow, T., Carela-Español, V., Sole-Pareta, J., Barlet-Ros, P.: A survey on web tracking: mechanisms, implications, and defenses. Proc. IEEE **105**(8), 1476–1510 (2017)
57. Ernst, N., Kazman, R., Delange, J.: Technical Debt in Practice: How to Find It and Fix It. MIT Press, Cambridge, MA (2021)
58. Malatras, A., Stanic, Z., Lella, I., De Sousa Figueiredo, R., Tsekmezoglou, E., Theocharidou, M., Naydenov, R., Drougkas, A.: Enisa threat landscape: transport sector (January 2021 to October 2022) (2023)
59. Li, R., Zhang, Z., Shao, J., Lu, R., Jia, X., Wei, G.: The potential harm of email delivery: investigating the https configurations of webmail services. IEEE Trans. Dependable Secur. Comput. **21**(1), 125–138 (2023)
60. Calzavara, S., Rabitti, A., Bugliesi, M.: Semantically sound analysis of content security policies. In: International Conference on Formal Techniques for Distributed Objects, Components, and Systems, pp. 293–297. Springer (2019)
61. Nagasundari, S., Banakar, N., Ponnukailasam, M.: Dynamic content security policy generation and management using url safety verification, (2025)
62. Aryaman, N., Vollala, N.S., Amin, S., R.: Detecting and predicting countermeasures against clickjacking. Secur. Priv. **6**(5), 302 (2023)
63. Riberu, L.H., Emanuel, A.W.R.: 2024 international conference of adisutjipto on aerospace electrical engineering and informatics (ICAAEEI), pp. 1–5. IEEE (2024). (**Vulnerability testing and analysis using owasp top 10 on academic information system at university xyz**)
64. Italian Ministry of Health: Aziende Sanitarie Locali - ASL. https://www.dati.salute.gov.it/it/dataset/aziende-sanitarie-locali-asl/. Open Data dataset (2026). Accessed 24 Aug 2026
65. Italian Ministry of Health: Elenco Aziende sanitarie locali e Strutture di ricovero. https://www.salute.gov.it/new/it/banche-dati/elenco-aziende-sanitarie-locali-e-strutture-di-ricovero (2026). Accessed 24 Aug 2026
66. Italian Public Administration Index: Indice dei domicili digitali delle Pubbliche Amministrazioni e dei Gestori di Pubblici Servizi. https://www.indicepa.gov.it/ (2026). Accessed 24 Aug 2026
67. Agenzia per l'Italia Digitale: Indice PA. https://www.agid.gov.it/it/dati/basi-dati-interesse-nazionale/indice-pa (2026). Accessed 24 Aug 2026

Publisher's Note Springer Nature remains neutral with regard to jurisdictional claims in published maps and institutional affiliations.